

Trust Me, I'm a Certificate Authority

PyCon PT 2026 Tutorial

Tiago Montes



DISCLAIMER

THIS IS TEACHING MATERIAL, NOT SECURITY SOFTWARE.

IT CUTS CORNERS ON PURPOSE.

SEVERAL EXERCISES ARE DELIBERATELY BROKEN.

REAL SECURITY IS A GREAT DEAL MORE THAN THIS.

USE NONE OF IT FOR ANYTHING THAT MATTERS.

NEVER TRUST A CA YOU BUILT HERE.

Trust Me, I'm a Certificate Authority

RSA	Keys, encryption, and signatures.
Certificates	Binding keys to identities (yay X.509)
CAs and TLS	Certificate Authorities, HTTPS clients/servers
MITM	Interception: where trust actually lives
Break Stuff	Certificates that fail, checks that catch them

Setup

Setup

targeting Python ≥ 3.12

Setup

targeting Python ≥ 3.12

Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

Setup

targeting Python ≥ 3.12

Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

with uv

```
$ uv sync
```

Setup

targeting Python ≥ 3.12

Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

with uv

```
$ uv sync
```

without uv

```
$ python3 -m venv .venv  
$ source .venv/bin/activate  
$ python3 -m pip install -r requirements.txt
```


Setup

targeting Python ≥ 3.12

Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

with uv

```
$ uv sync
```

without uv

```
$ python3 -m venv .venv  
$ source .venv/bin/activate  
$ python3 -m pip install -r requirements.txt
```

- Use **python.exe** instead of **python3**.
- Activate with **.venv\Scripts\activate**, instead.

windows

Setup

targeting Python ≥ 3.12

Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

with uv

```
$ uv sync
```

Optionally activate the virtual environment.

without uv

```
$ python3 -m venv .venv  
$ source .venv/bin/activate  
$ python3 -m pip install -r requirements.txt
```

- Use **python.exe** instead of **python3**.
- Activate with **.venv\Scripts\activate**, instead.

windows

Setup

targeting Python ≥ 3.12

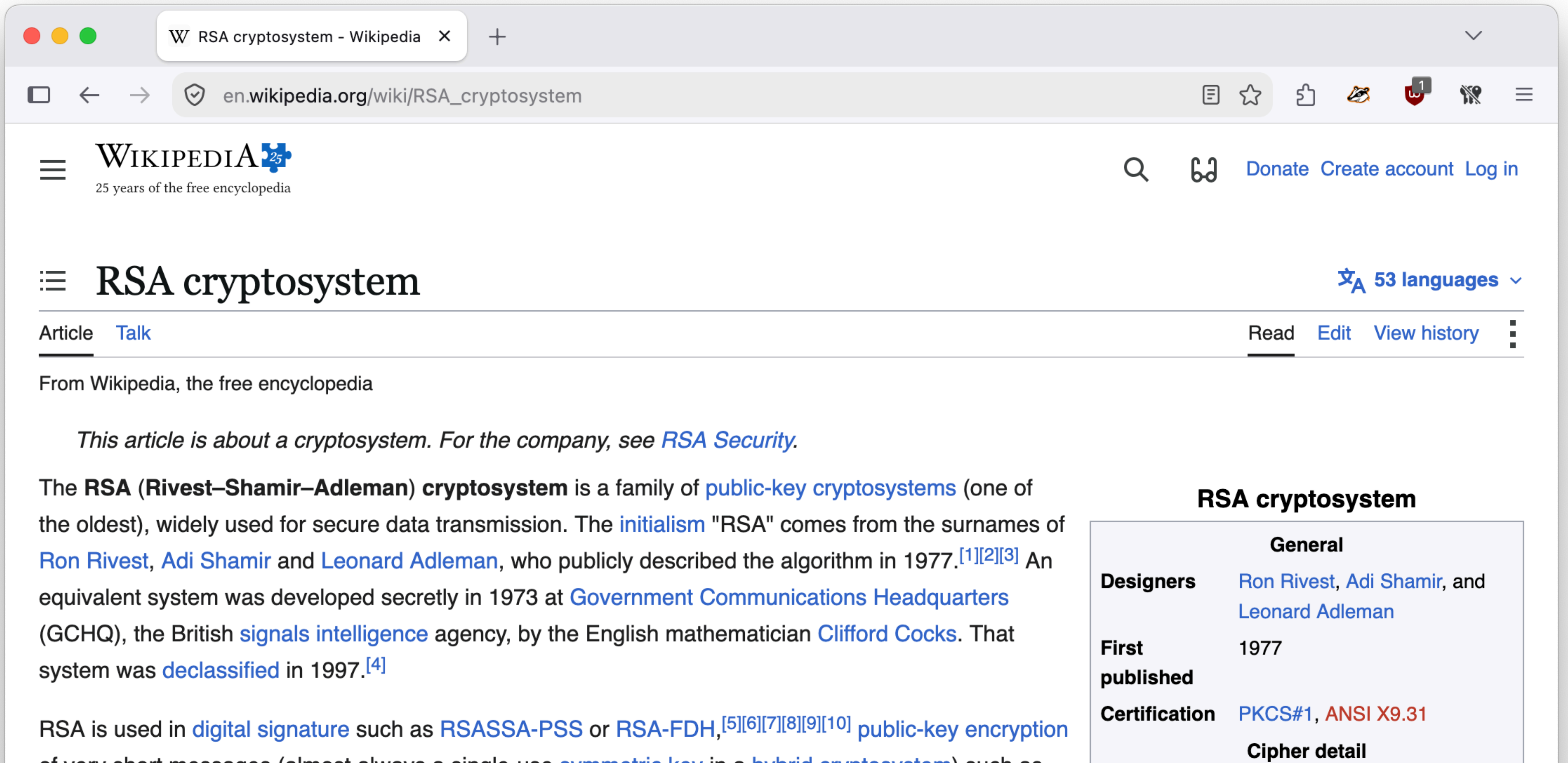
Clone <https://github.com/tmontes/pyconpt2026-tm-iaaca>

README.md

...no worries, it's all there!

RSA (Rivest–Shamir–Adleman)

RSA (Rivest–Shamir–Adleman)

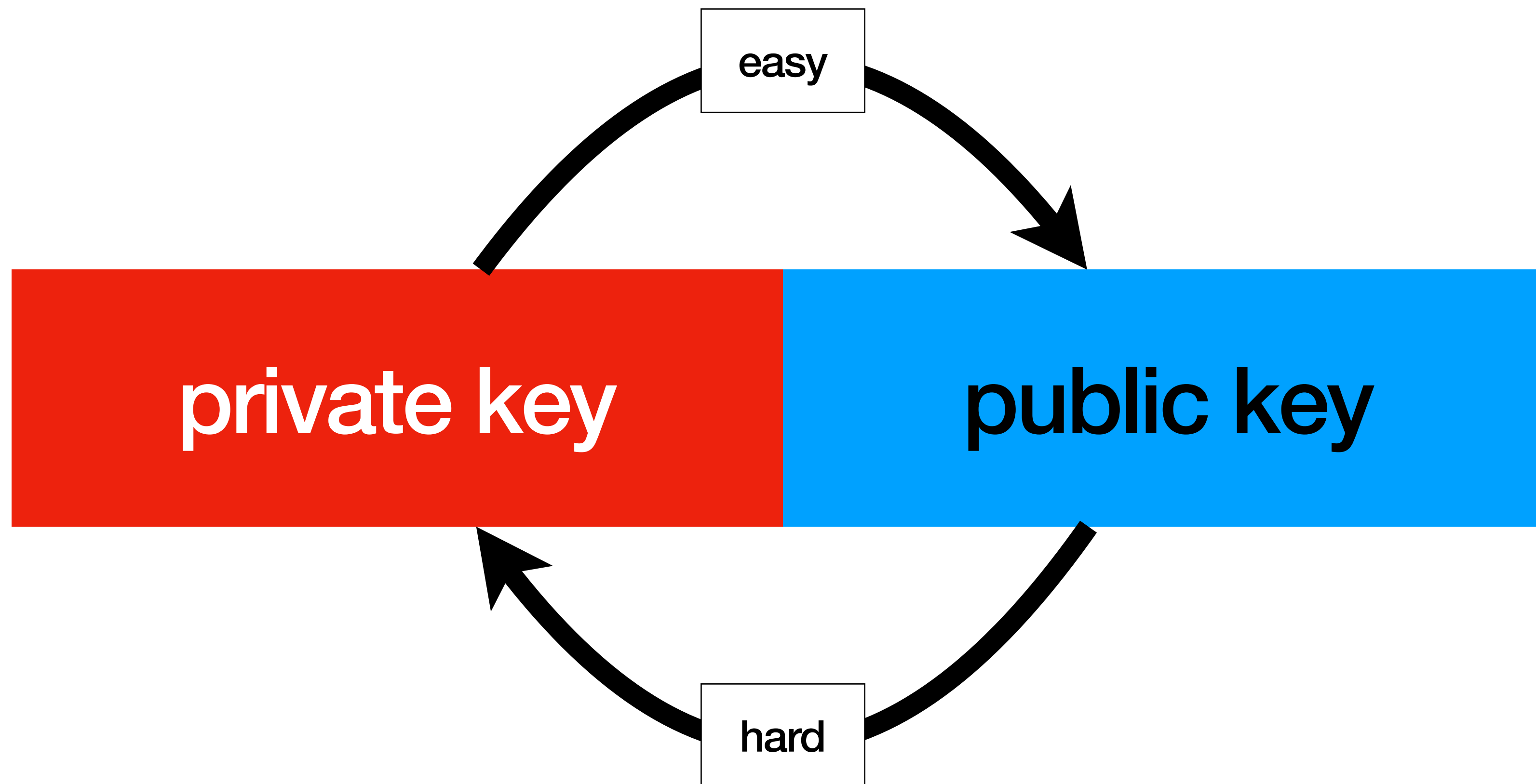


RSA key pair

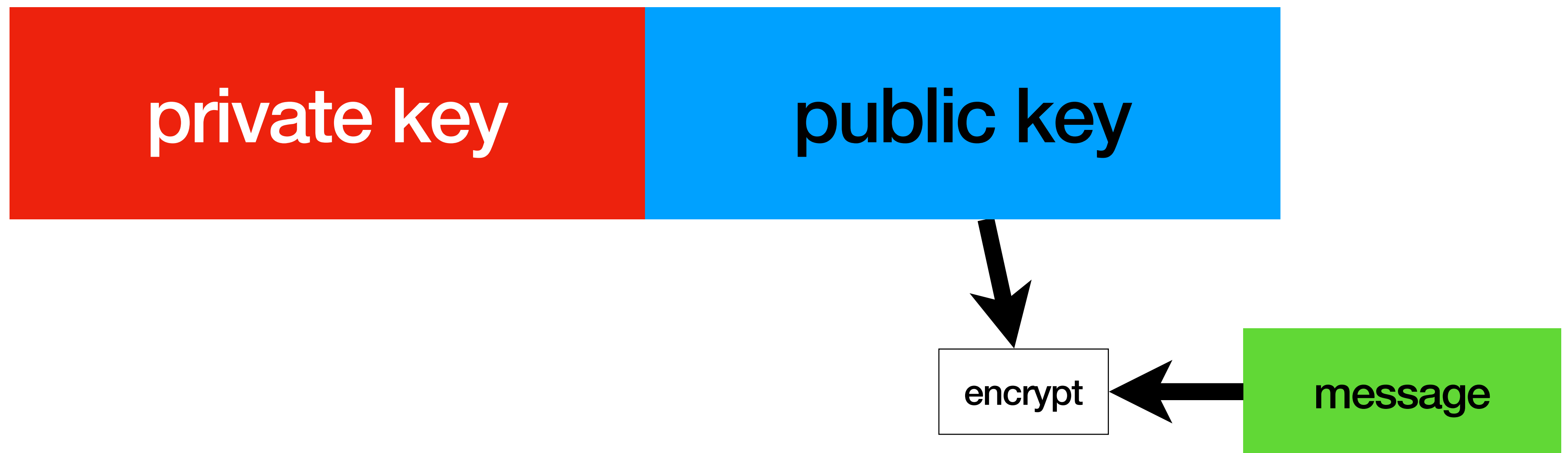
private key

public key

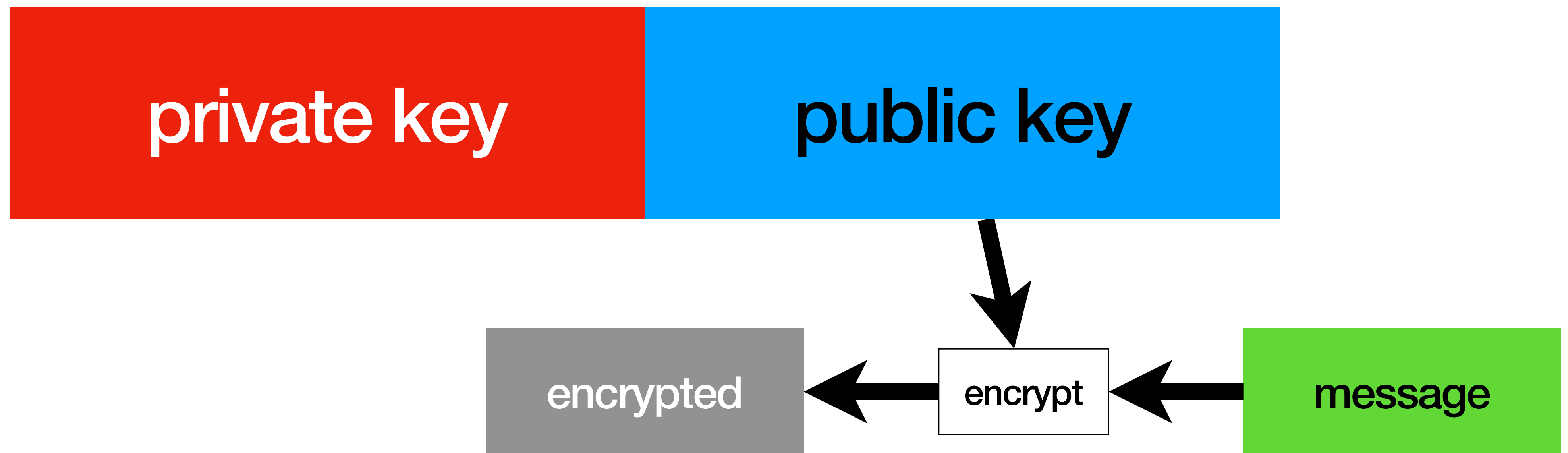
RSA key pair



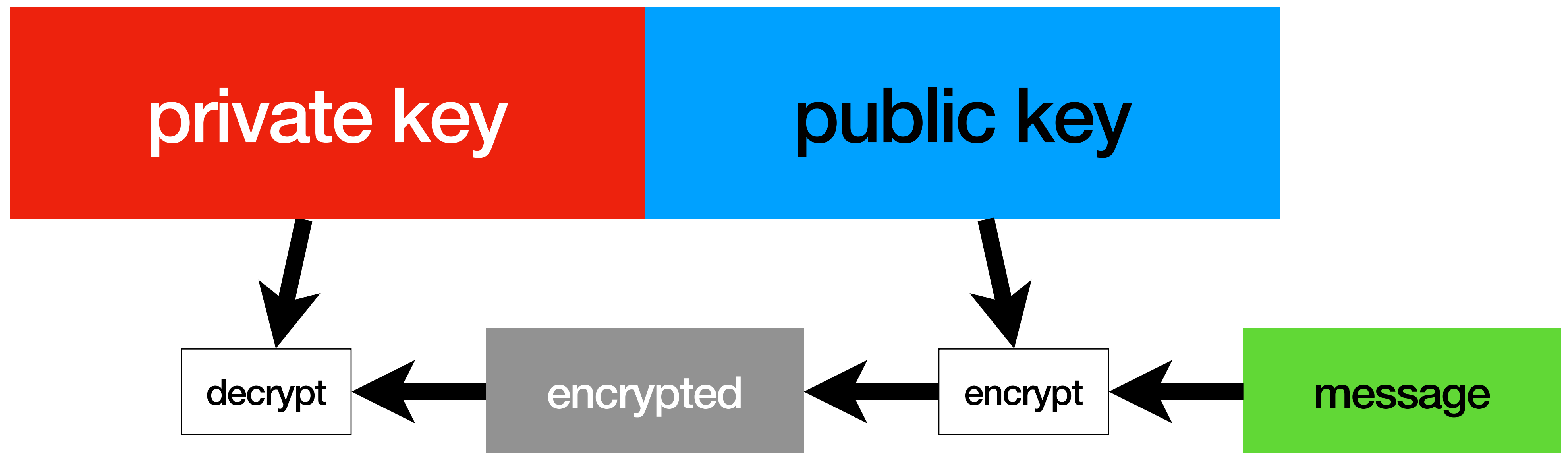
RSA operations



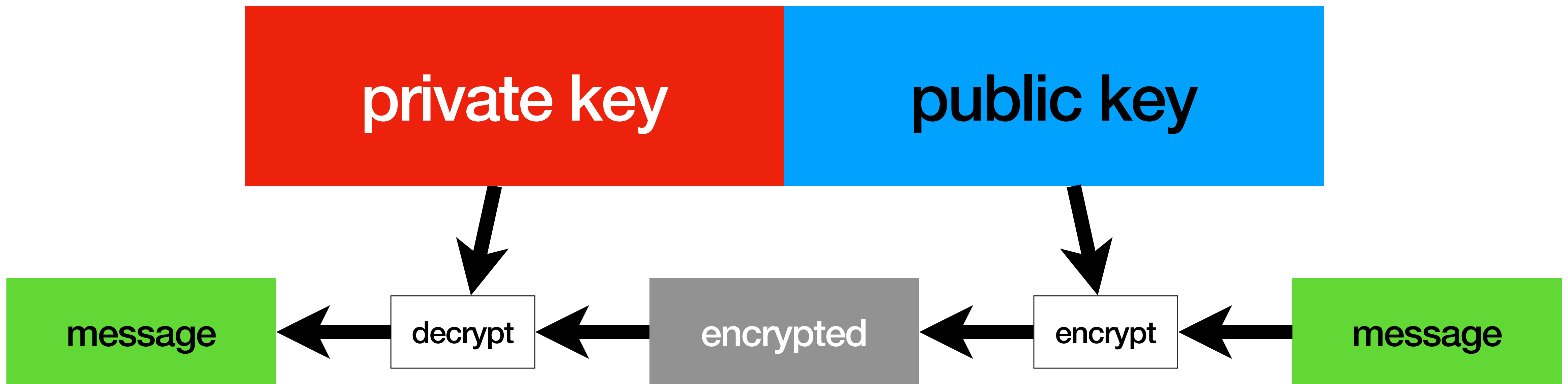
RSA operations



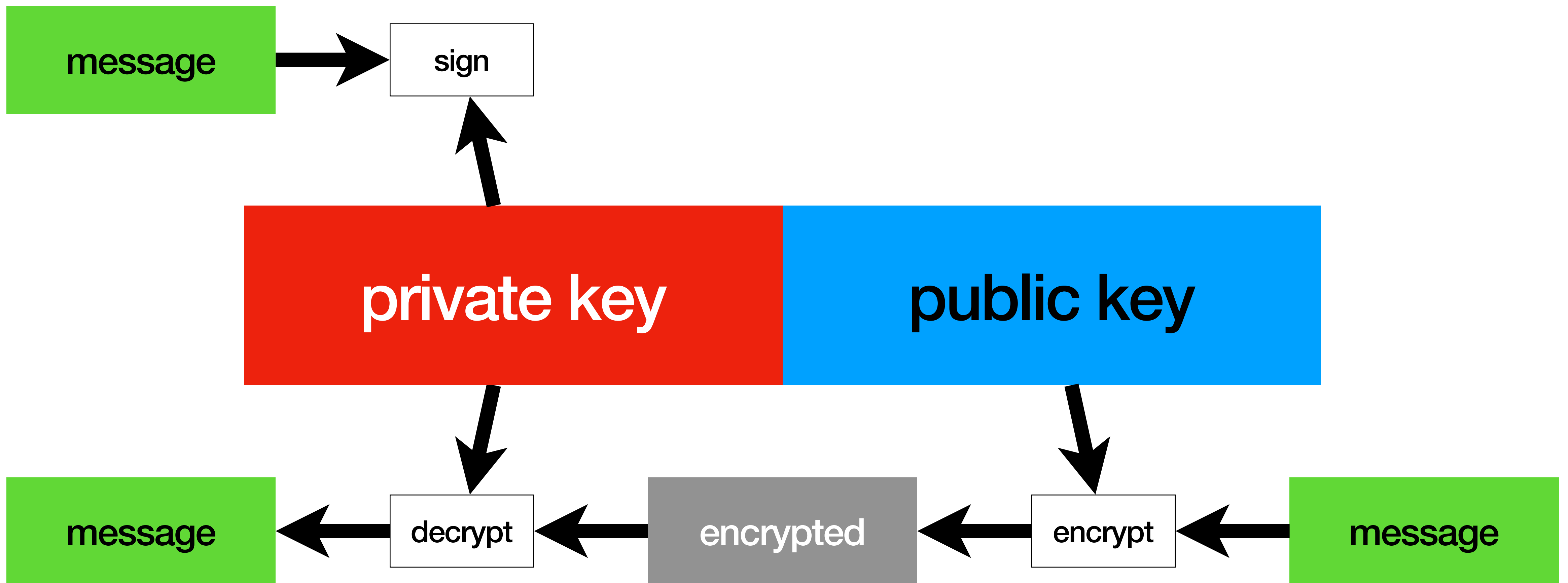
RSA operations



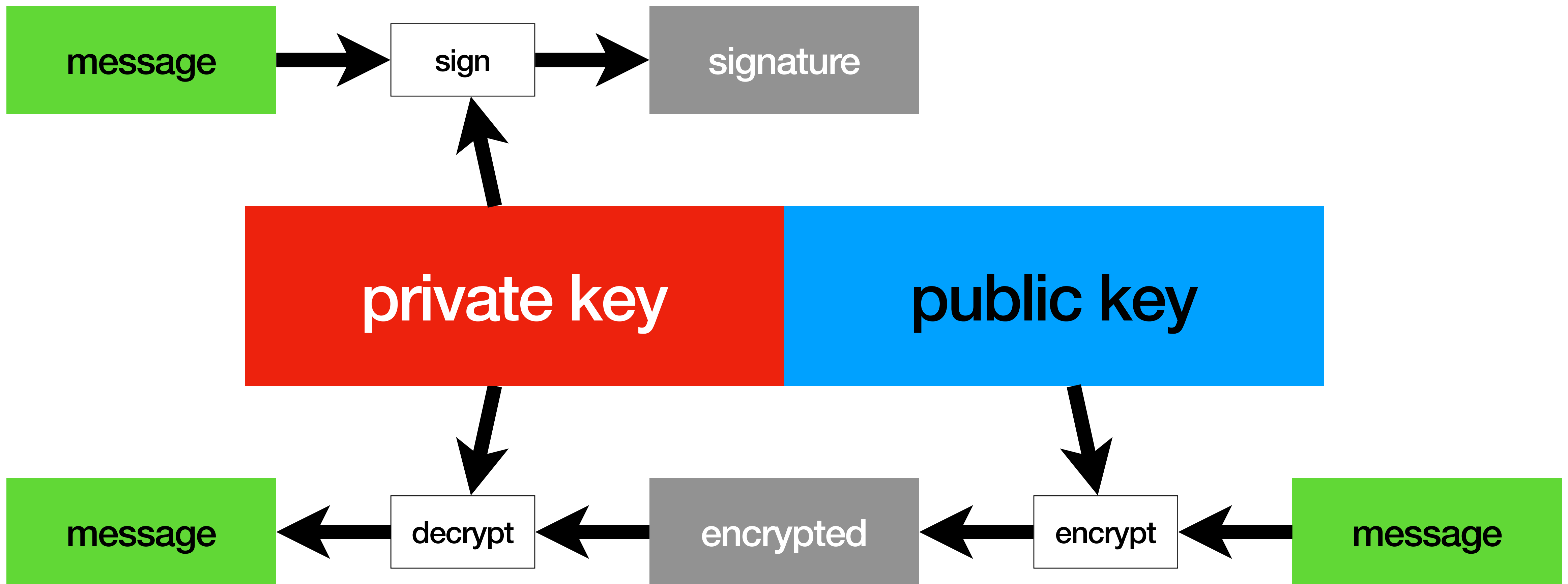
RSA operations



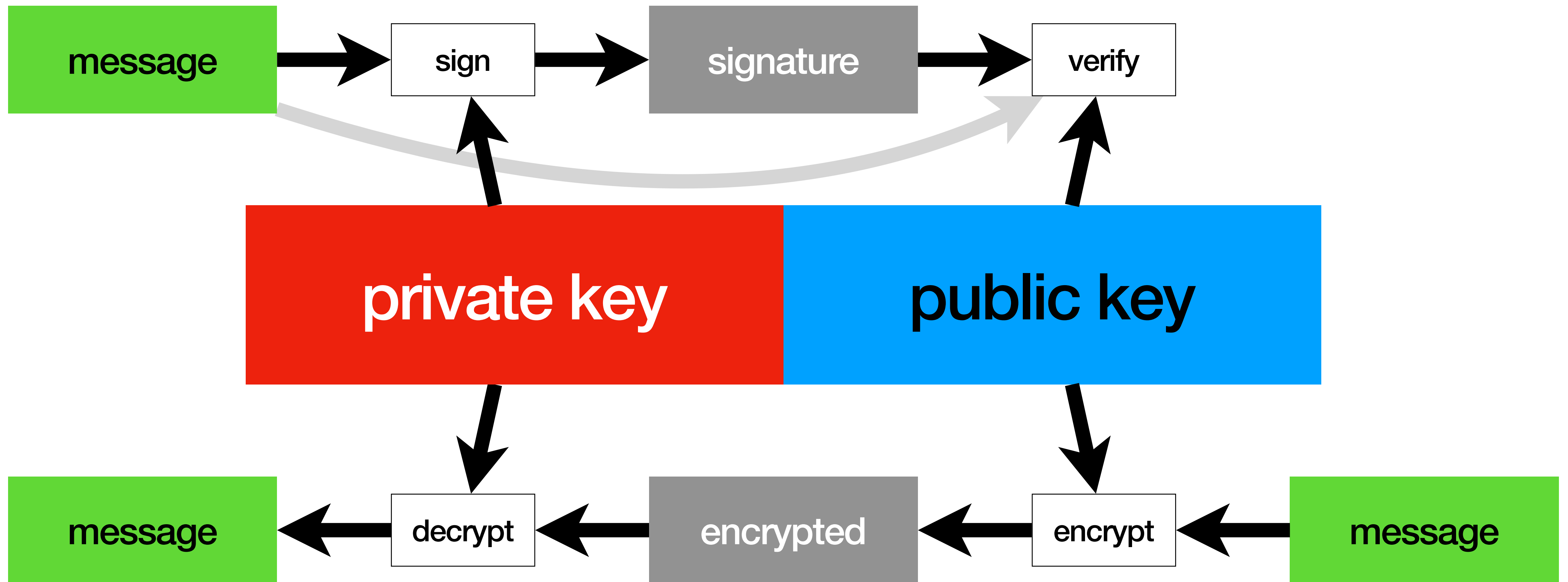
RSA operations



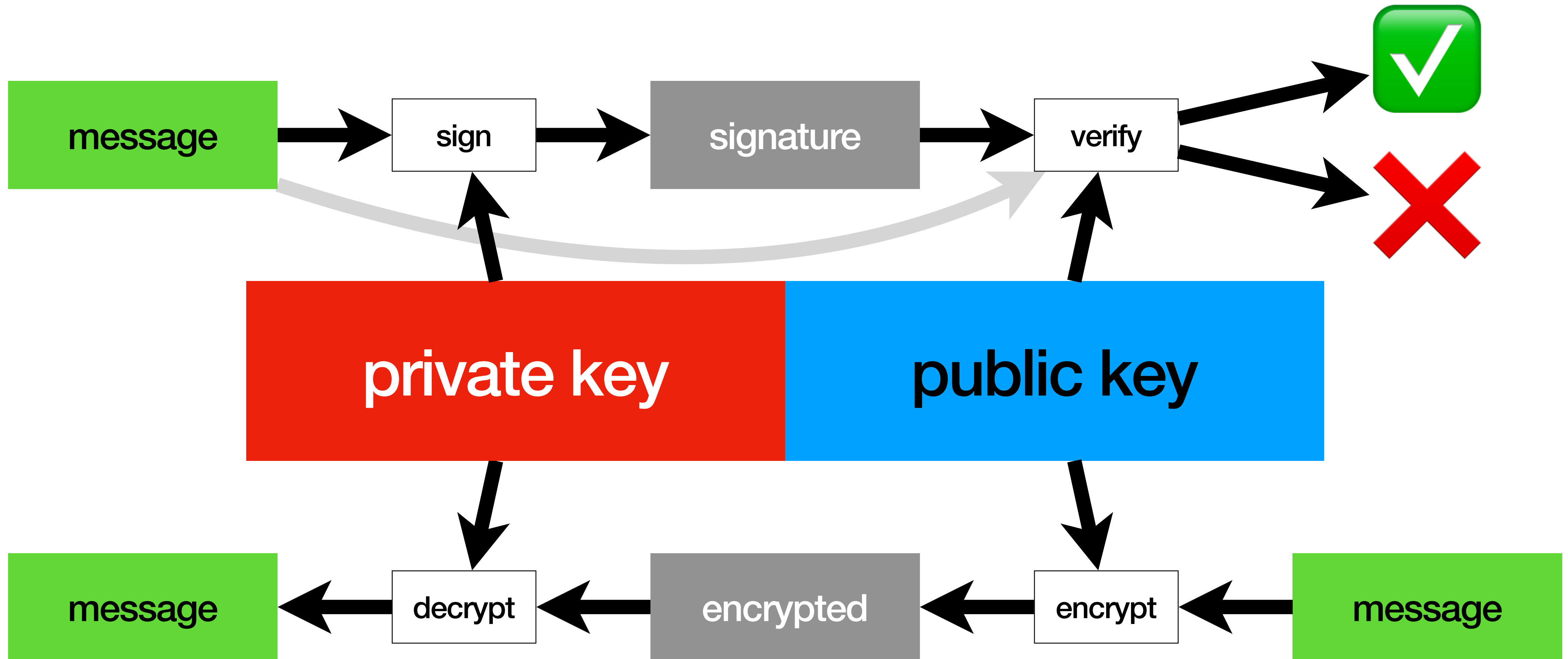
RSA operations



RSA operations



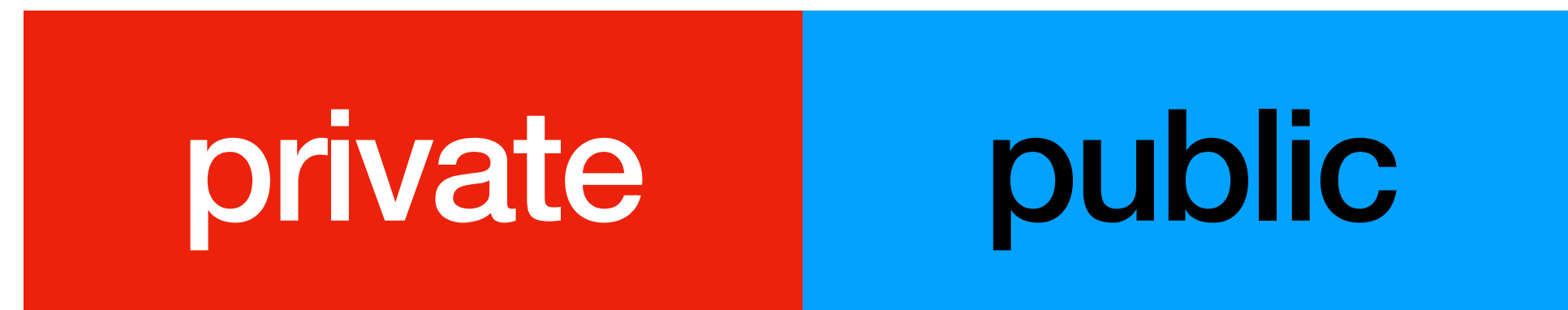
RSA operations



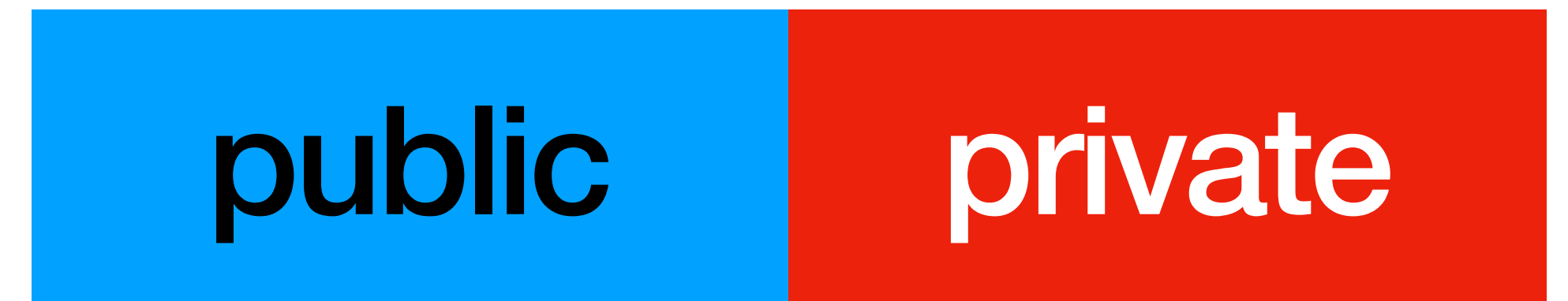
RSA private communication

RSA private communication

Alice

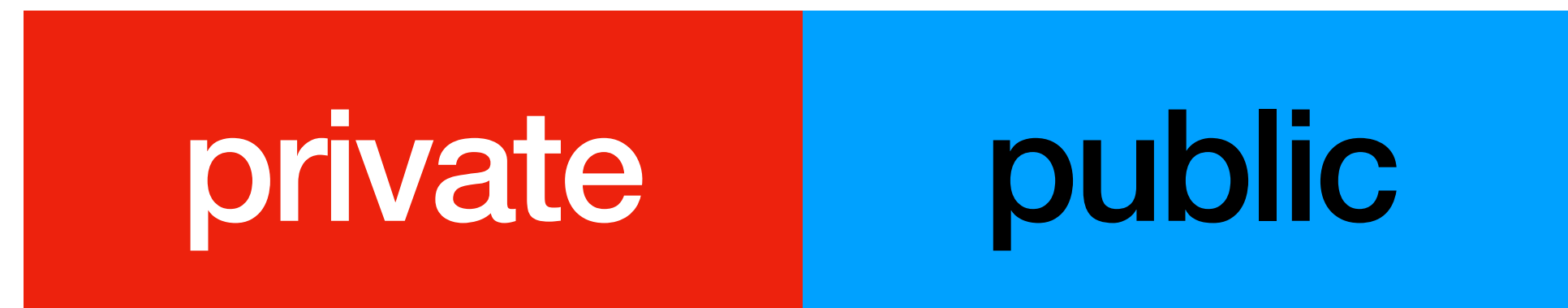


Bob

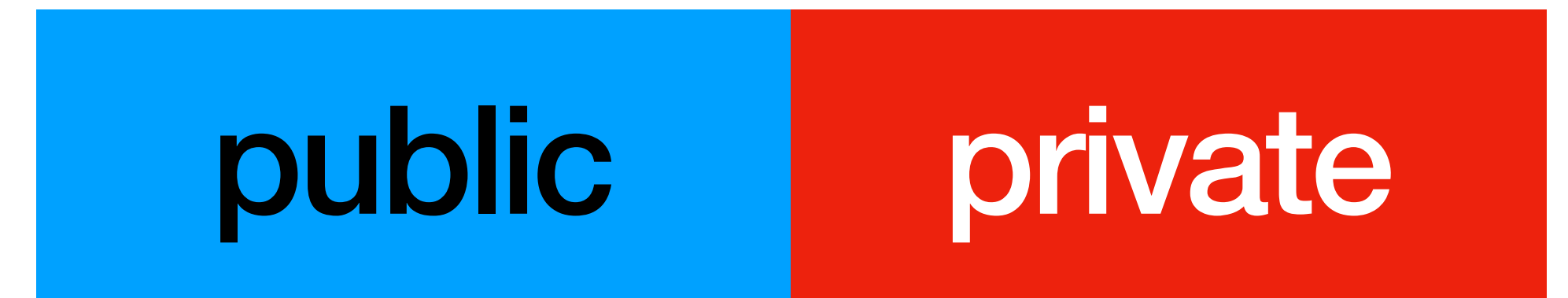


RSA private communication

Alice

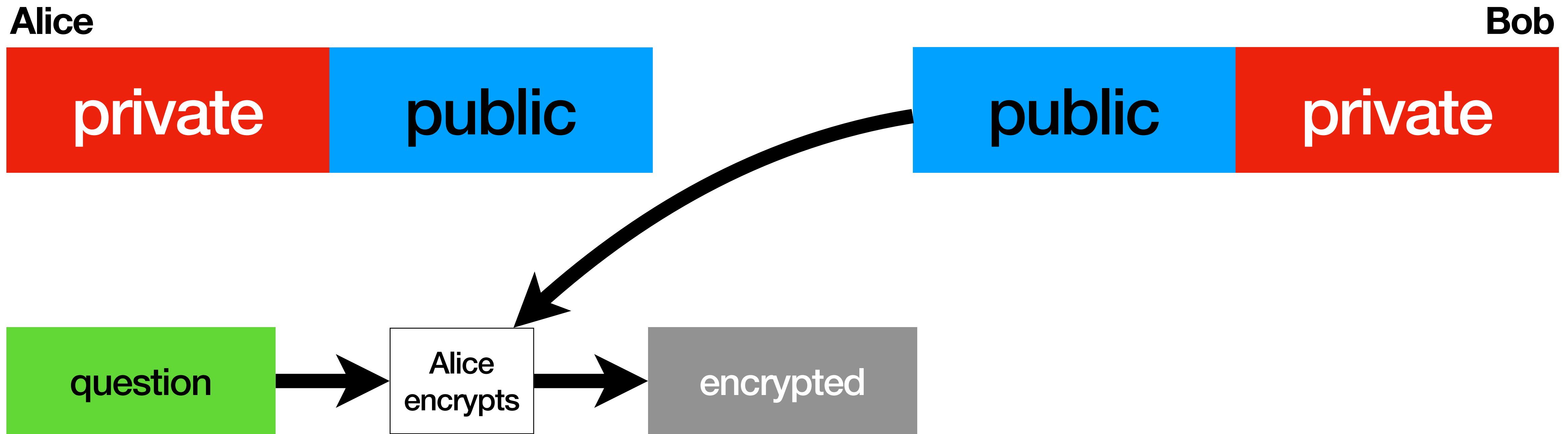


Bob



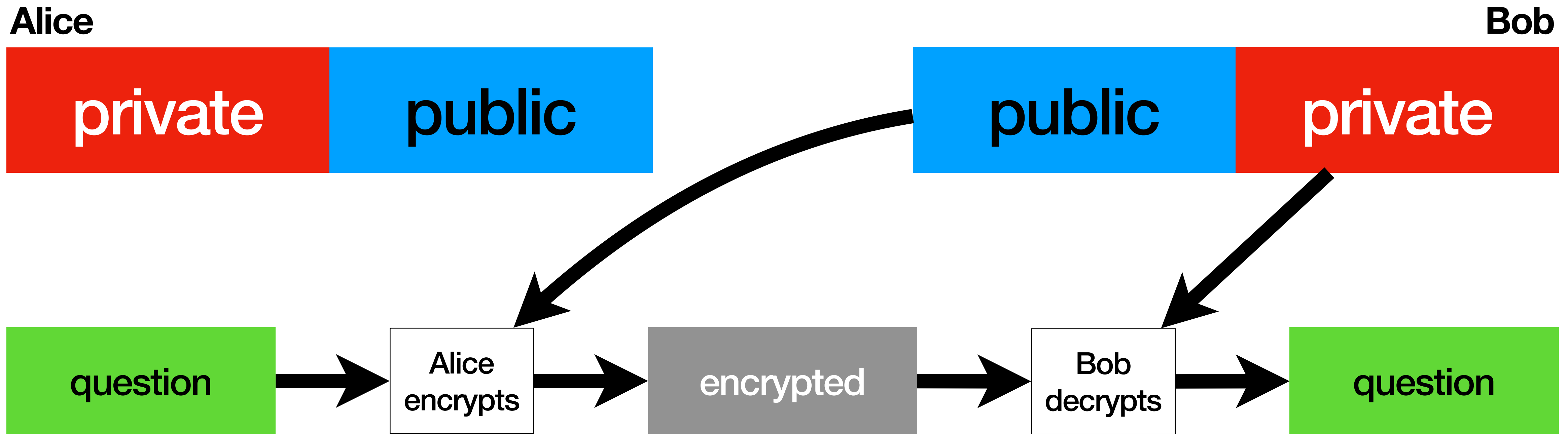
Alice sending a private question to **Bob**

RSA private communication



Alice sending a private question to **Bob**

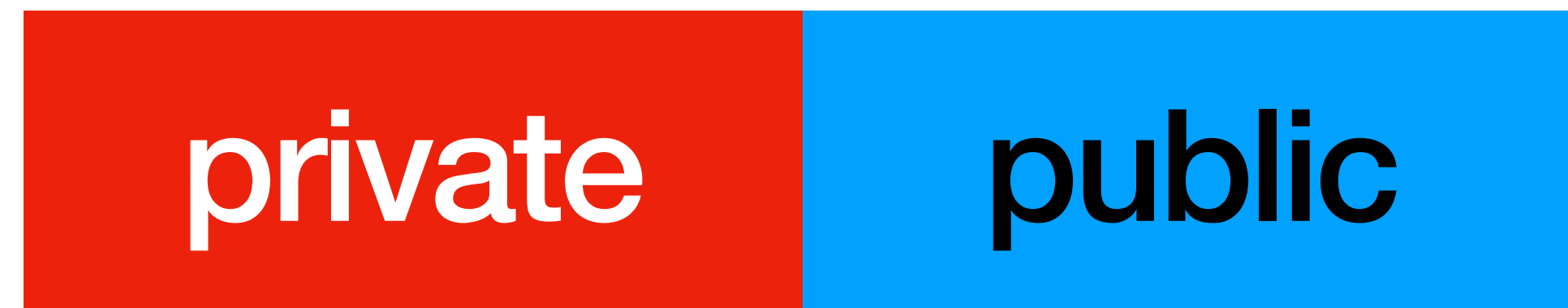
RSA private communication



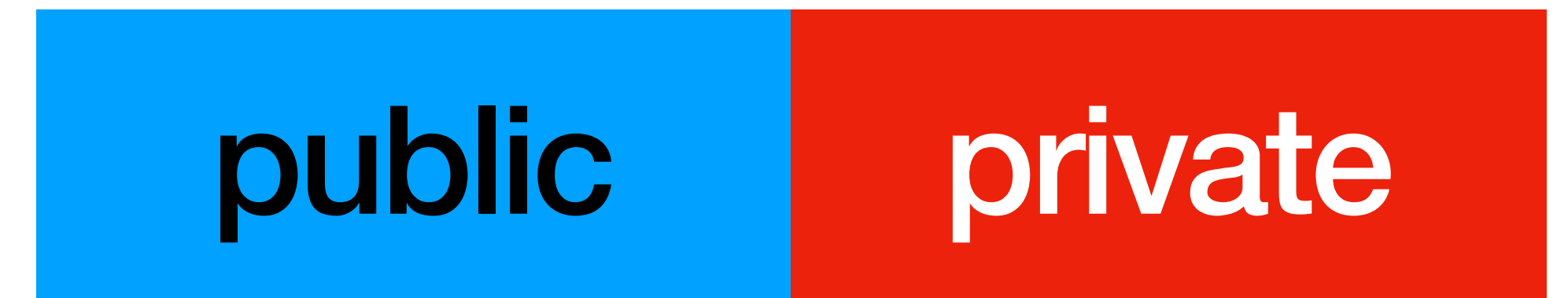
Alice sending a private question to **Bob**

RSA private communication

Alice

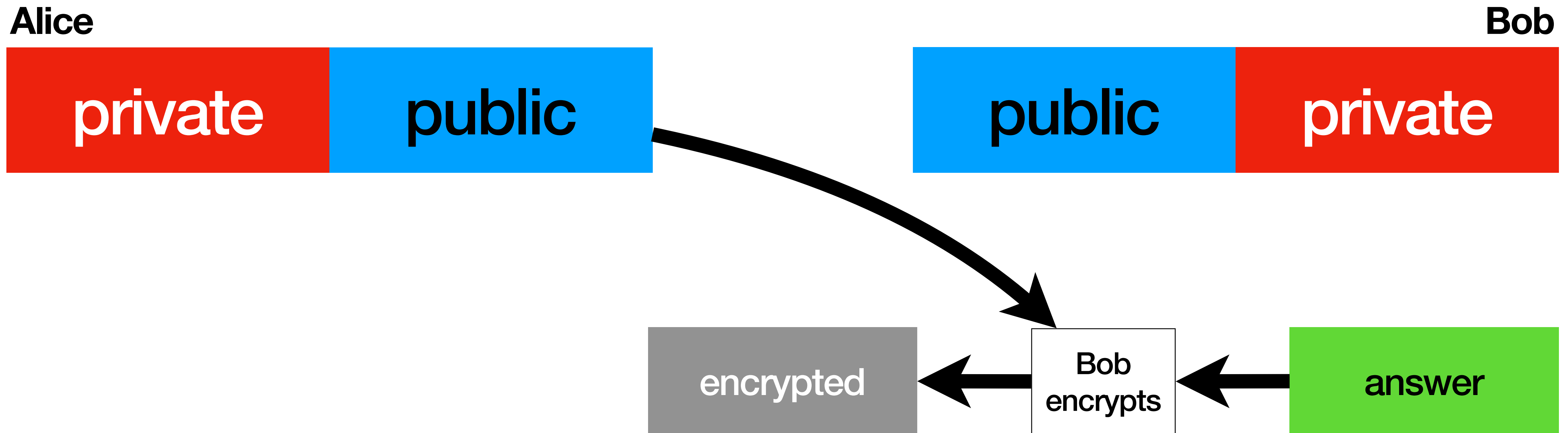


Bob



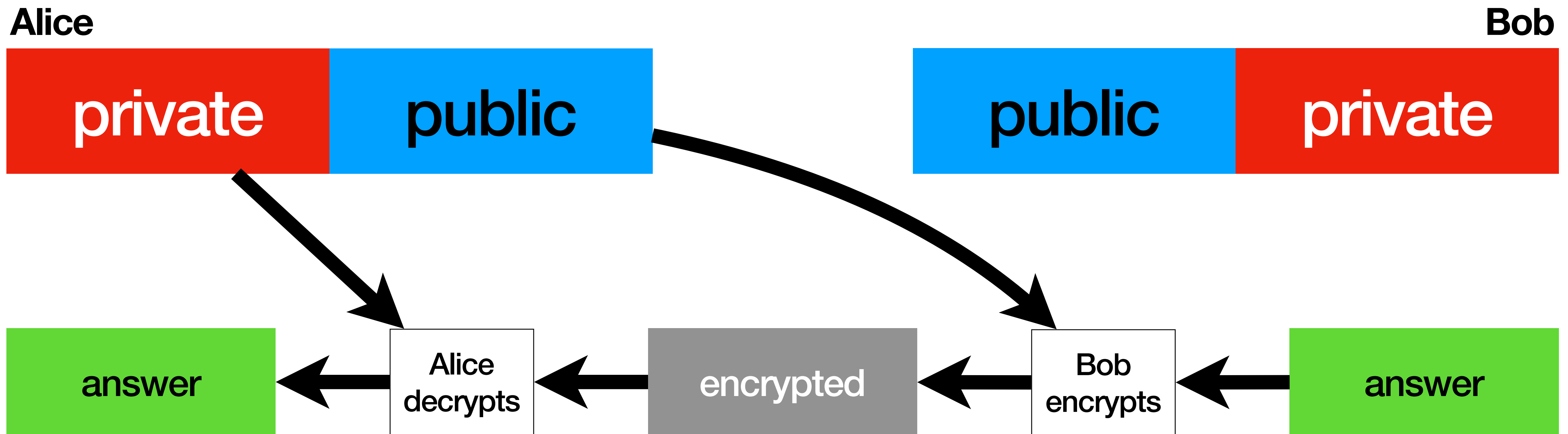
Bob sending a private answer to **Alice**

RSA private communication



Bob sending a private answer to **Alice**

RSA private communication

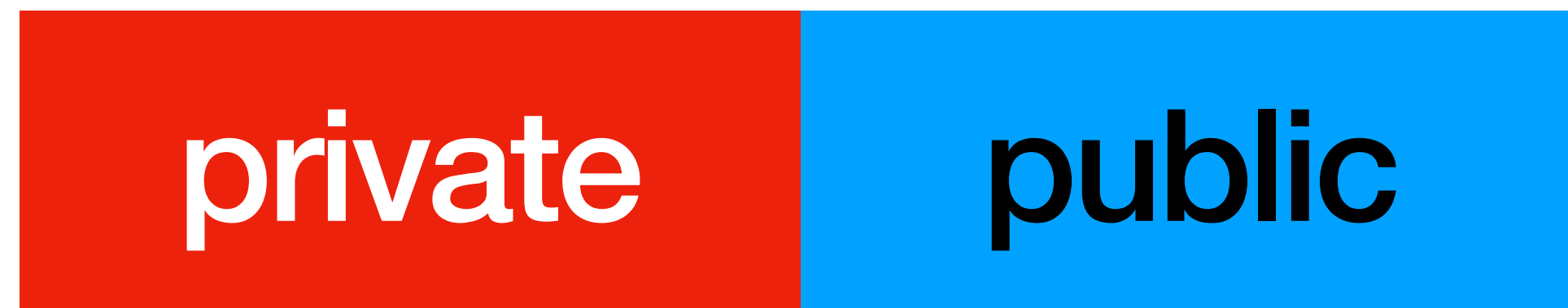


Bob sending a private answer to **Alice**

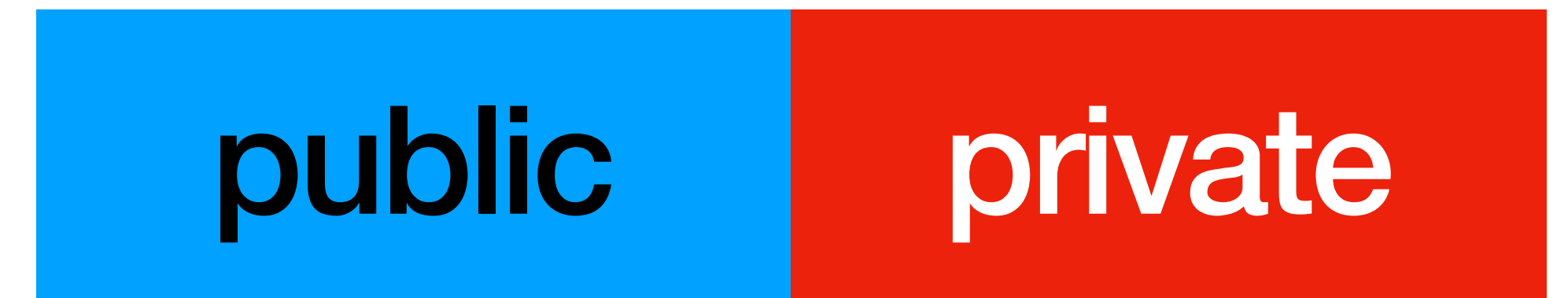
RSA signing / authentication

RSA signing / authentication

Alice

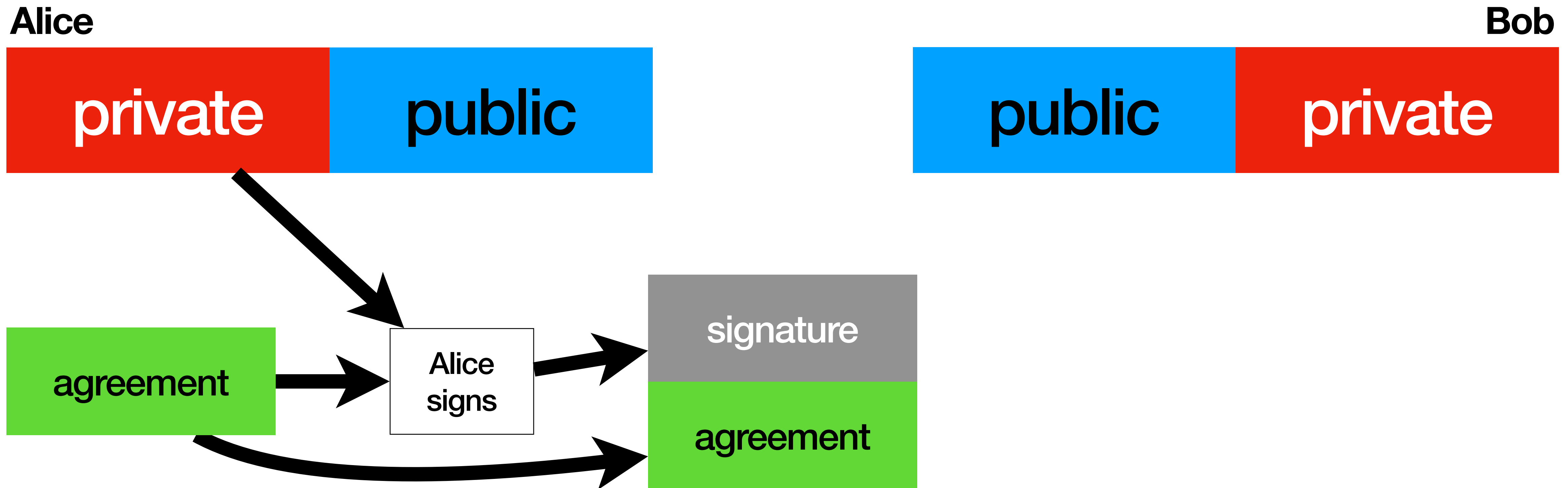


Bob



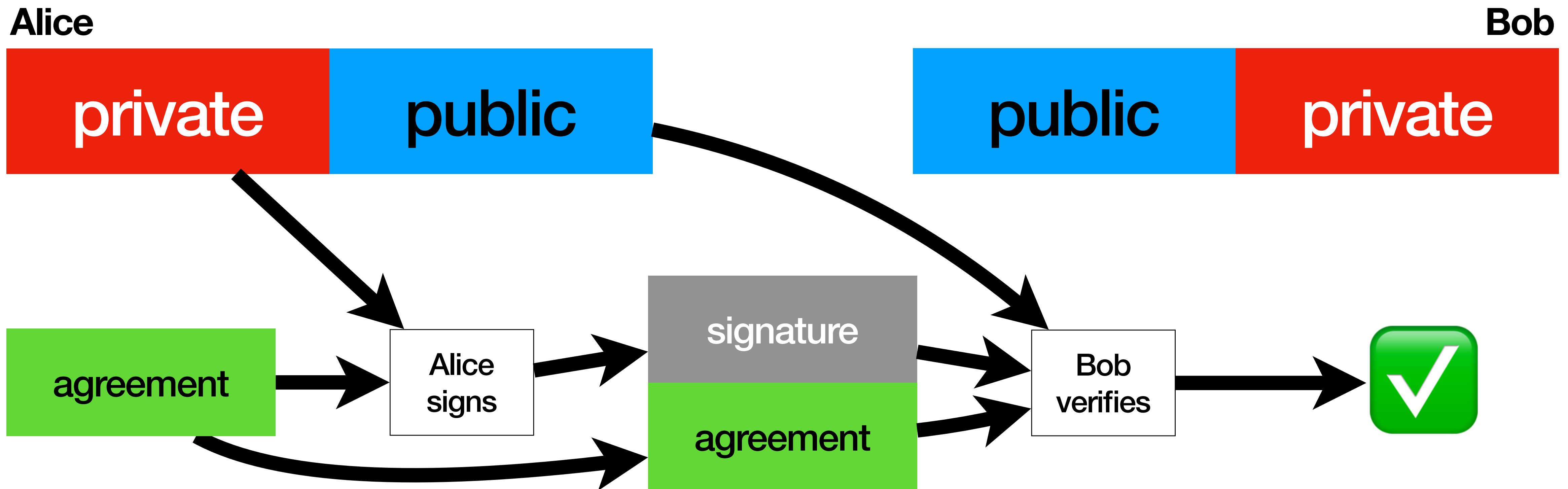
Alice sending an authenticated agreement to **Bob**

RSA signing / authentication



Alice sending an authenticated agreement to **Bob**

RSA signing / authentication

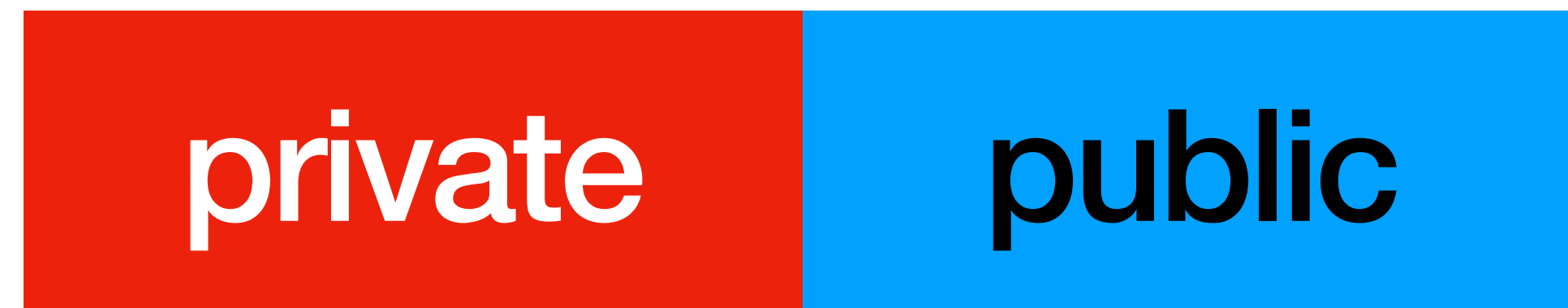


Alice sending an authenticated agreement to **Bob**

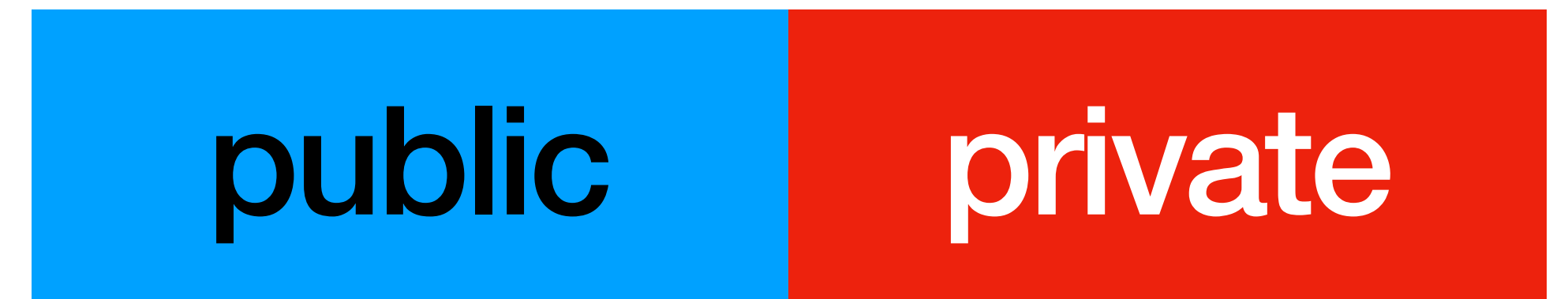
RSA private and authenticated

RSA private and authenticated

Alice

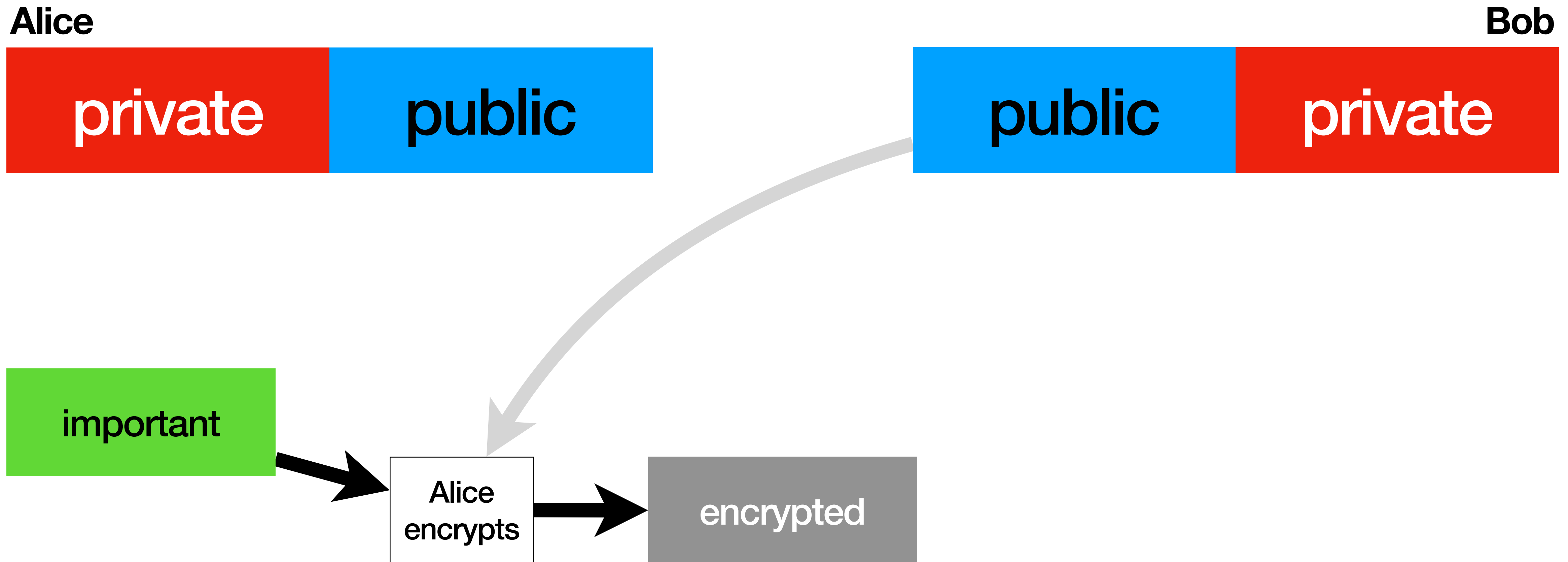


Bob

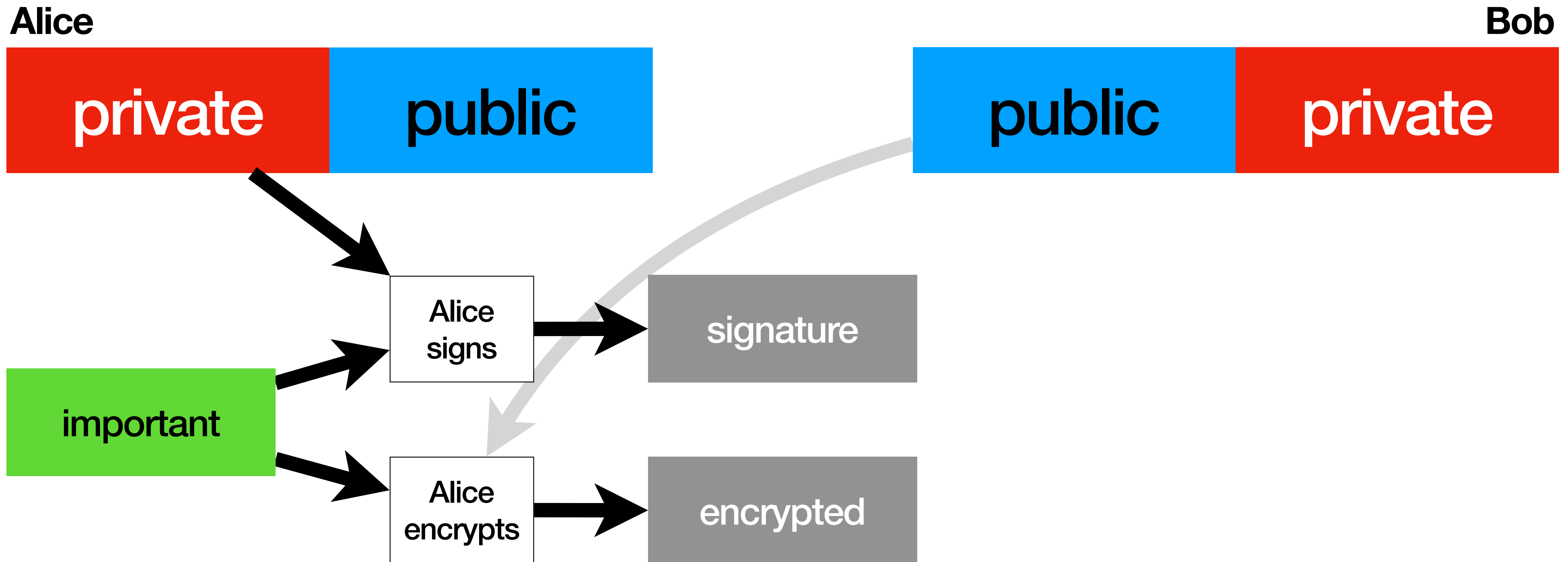


important

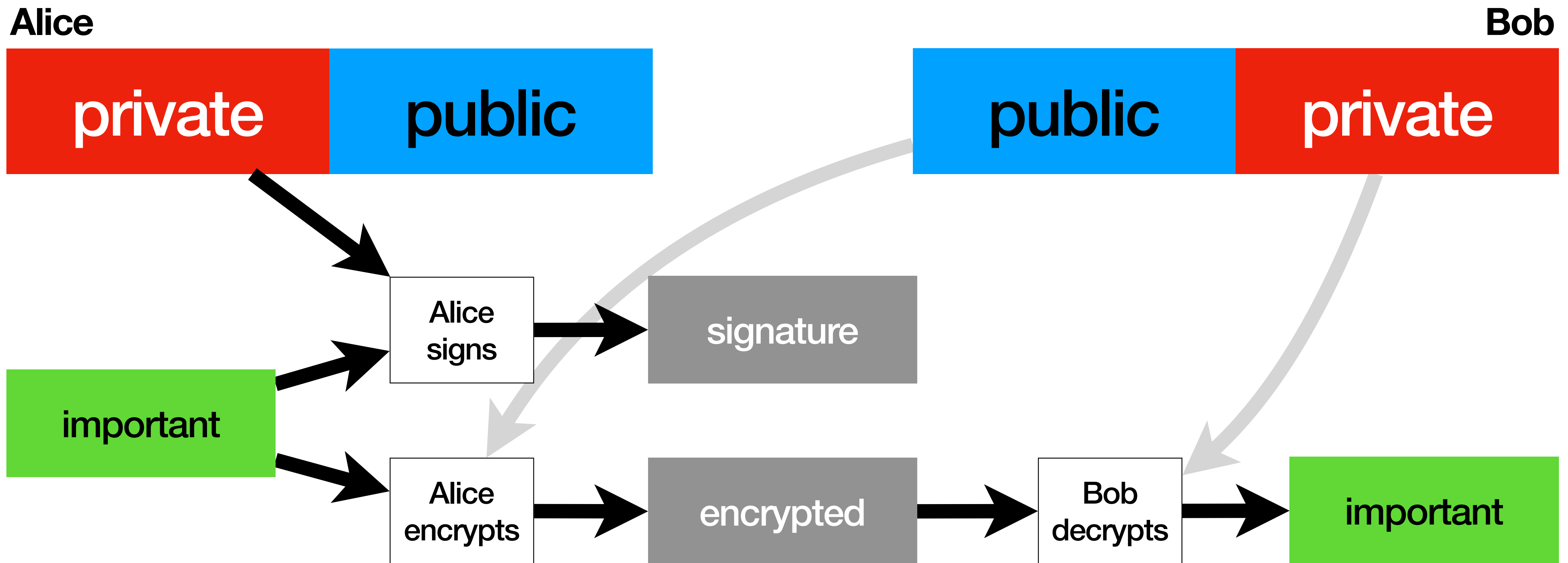
RSA private and authenticated



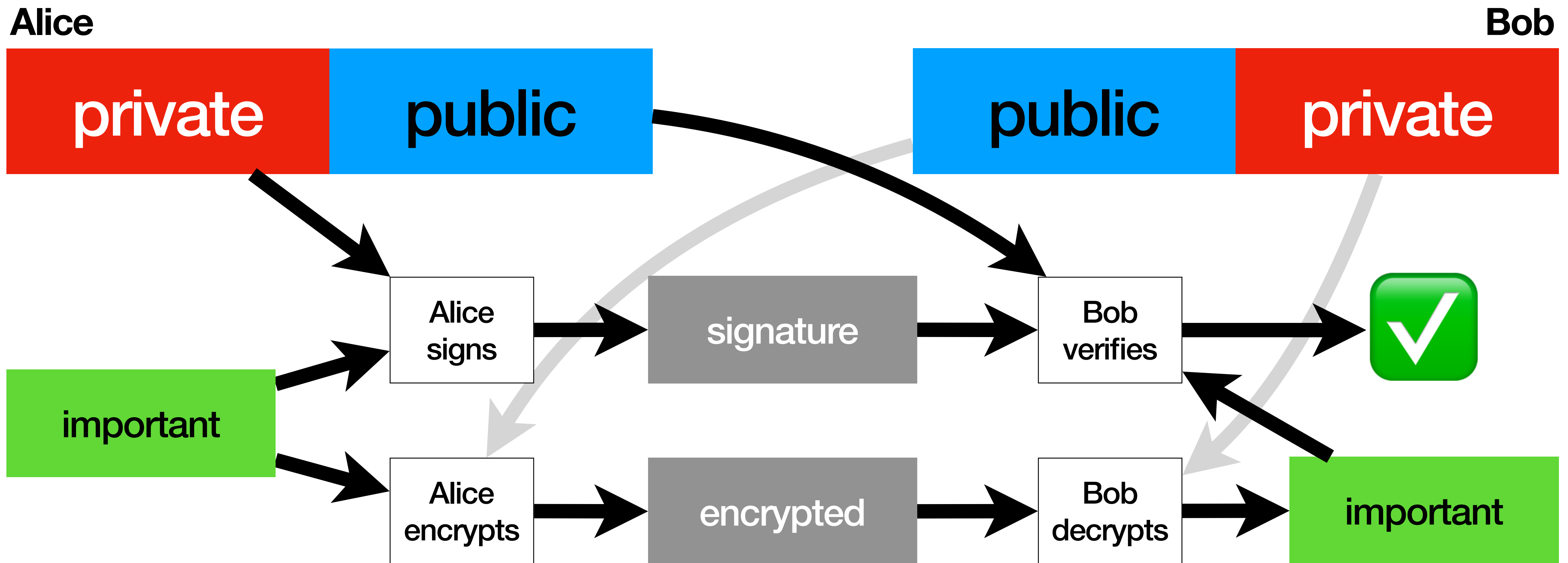
RSA private and authenticated



RSA private and authenticated



RSA private and authenticated



RSA

RSA

no way this is enough

X.509 Certificates

X.509 Certificates

issuer name

subject name

valid from

valid to

public key

signature

X.509 Certificates

issuer name
subject name
valid from
valid to
public key
signature

Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

X.509 Certificates

issuer name
subject name
valid from
valid to
public key
signature

the subject's

the issuer's

Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

X.509 Certificates

issuer name
subject name
valid from
valid to
public key
signature

the subject's

the issuer's

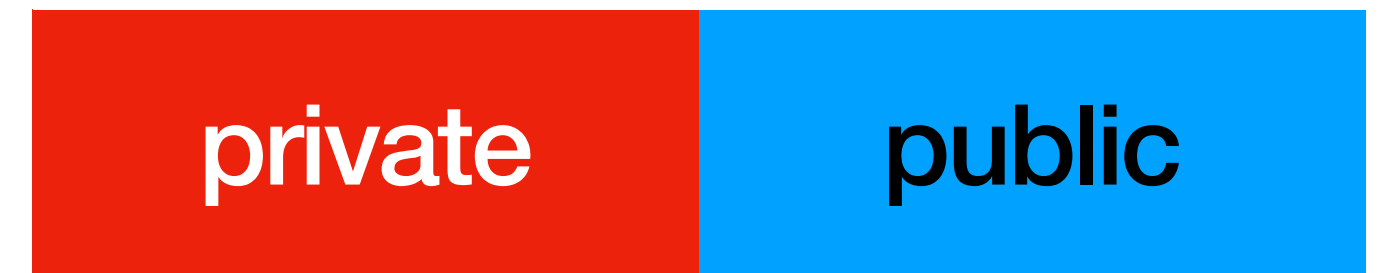
Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

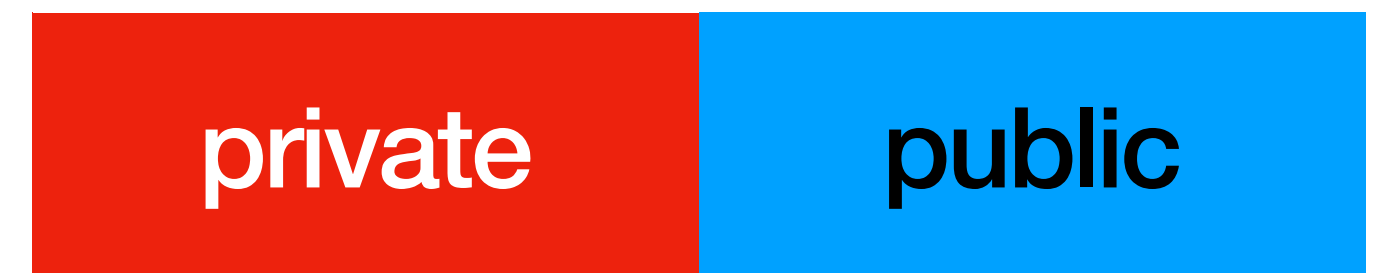
Certificates provide **Identity Assurance**

X.509 Certificates

Carol



Dave



Carol certifying this public key is **Dave's**

X.509 Certificates

issuer name	Carol
subject name	Dave
valid from	...
valid to	...
public key	
signature	

Carol

private

public

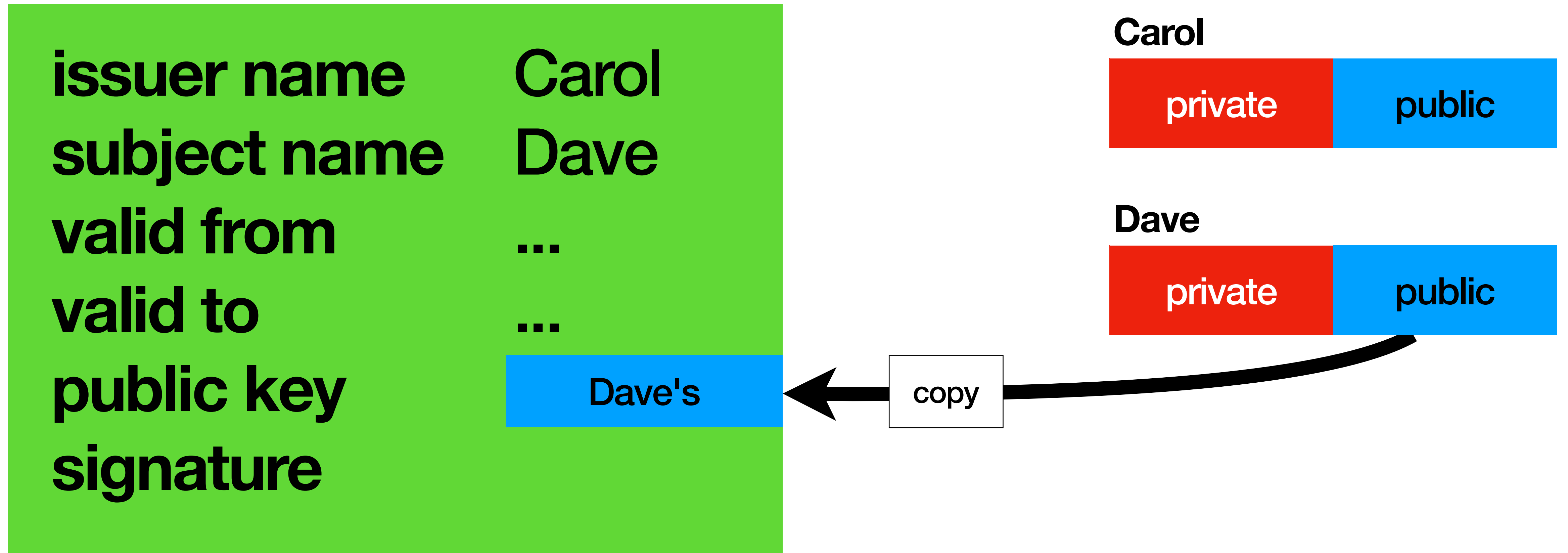
Dave

private

public

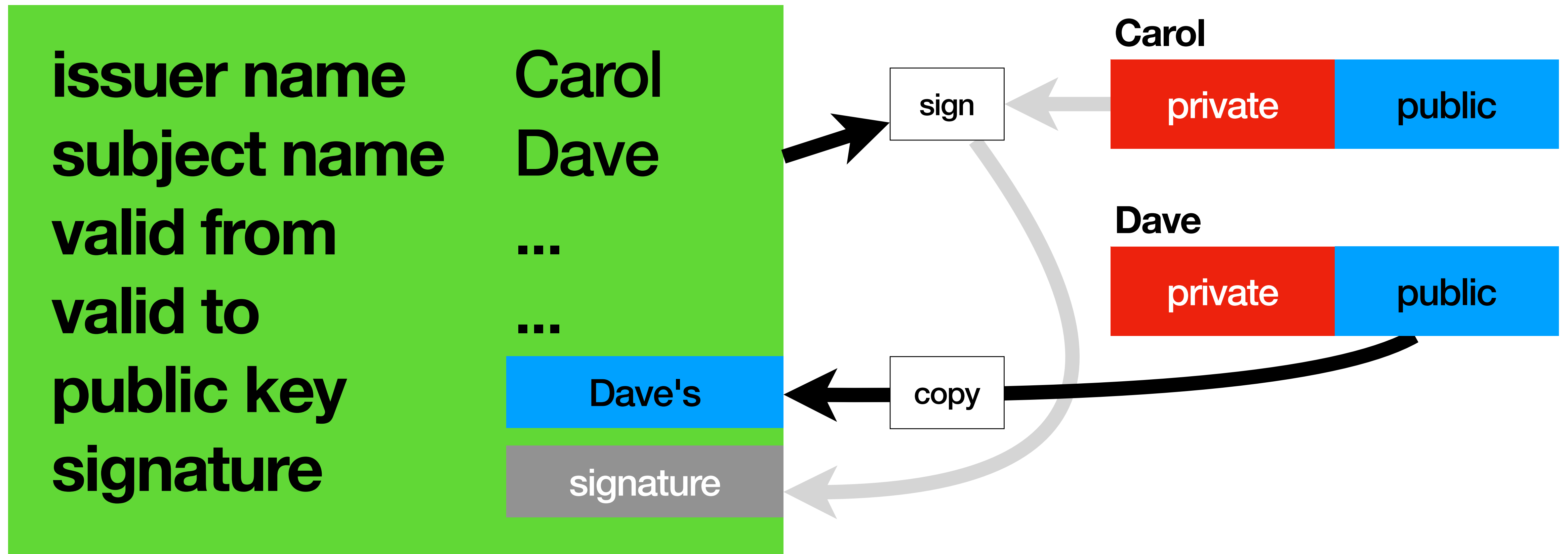
Carol certifying this public key is **Dave's**

X.509 Certificates



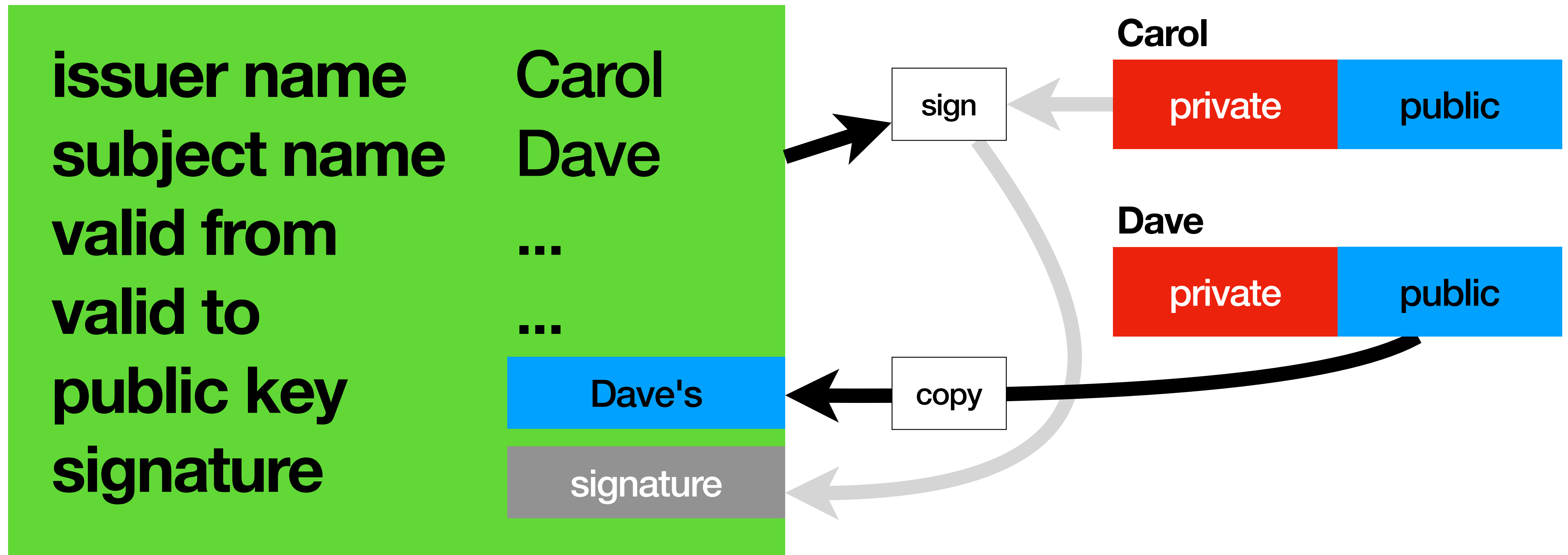
Carol certifying this public key is **Dave's**

X.509 Certificates



Carol certifying this public key is **Dave's**

X.509 Certificates



Certificates hold no secrets and are **public**.

X.509 Self-Signed Certificates

X.509 Self-Signed Certificates

issuer name	Bob
subject name	Bob
valid from	...
valid to	...
public key	
signature	

Bob

private

public

X.509 Self-Signed Certificates

issuer name	Bob
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	

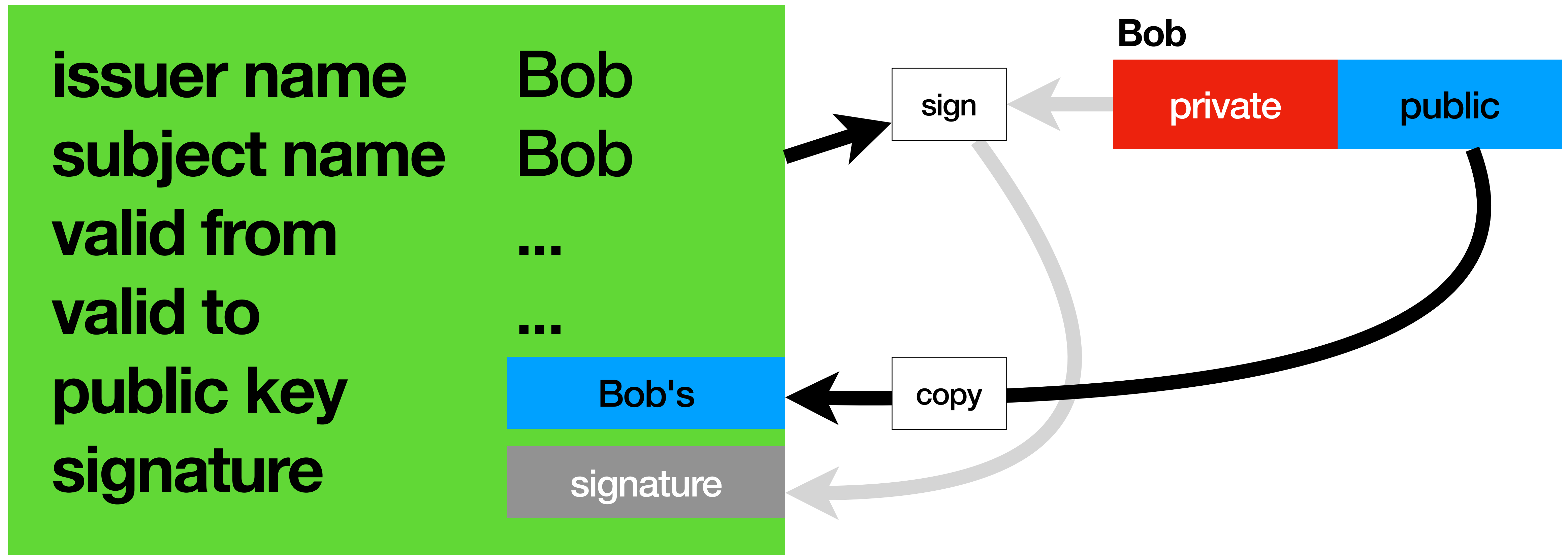
Bob

private

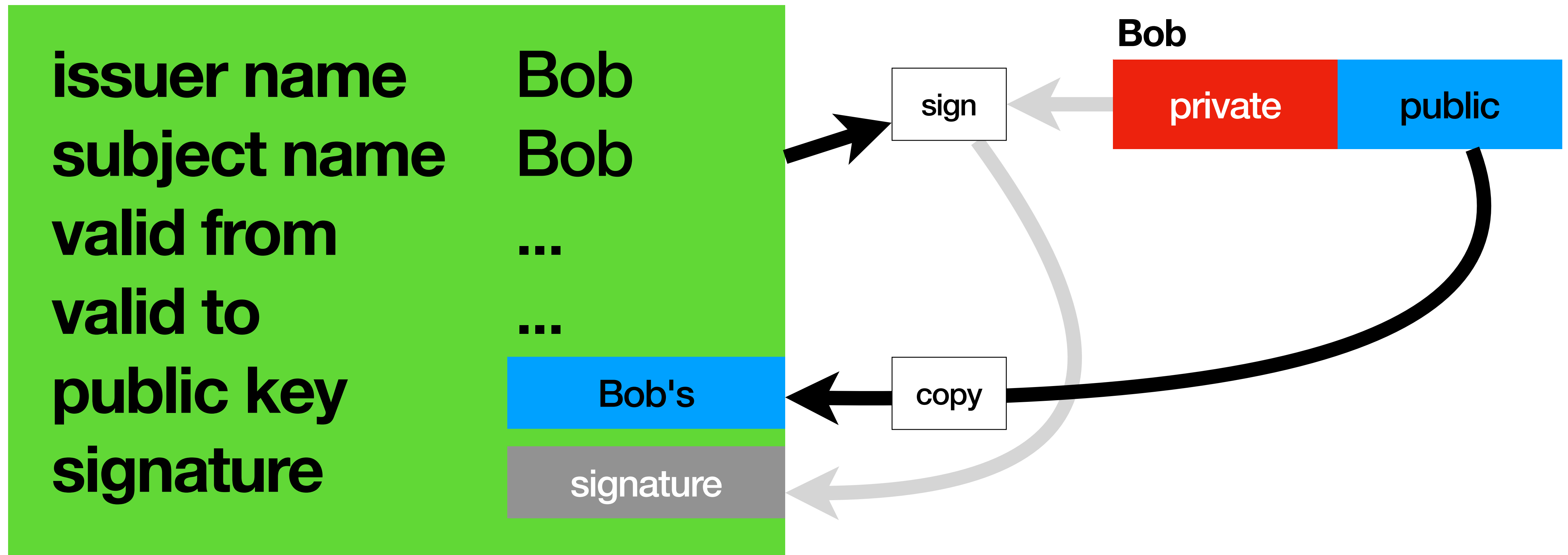
public

copy

X.509 Self-Signed Certificates



X.509 Self-Signed Certificates



Self-Signed Certificates are **auto proclamations of Identity**

Certificates

Certificates

no way self-signed certificates are enough

Certificate Authorities

Certificate Authorities

- Issue **Certificates**, by **signing** them

Certificate Authorities

- Issue **Certificates**, by **signing** them
- Using their own **private** key

CA

private

public

Certificate Authorities

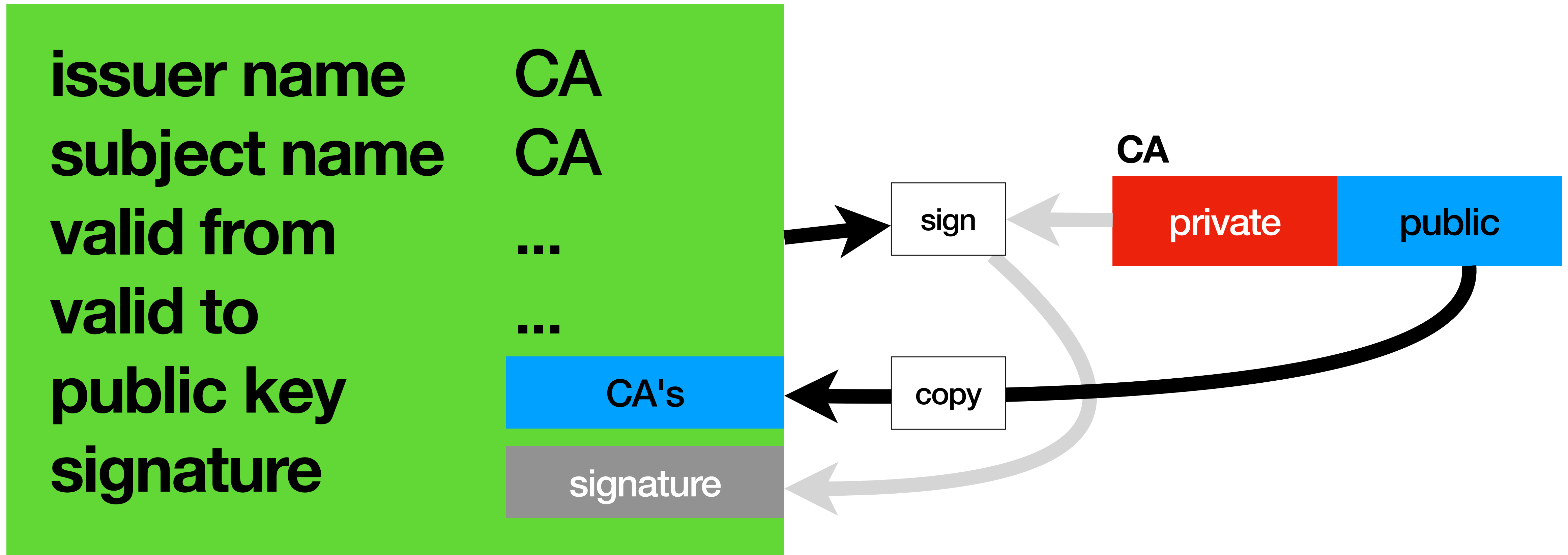
- Issue **Certificates**, by **signing** them
- Using their own **private** key
- And claim their own **Identity** via a **Self-Signed Certificate**

CA

private

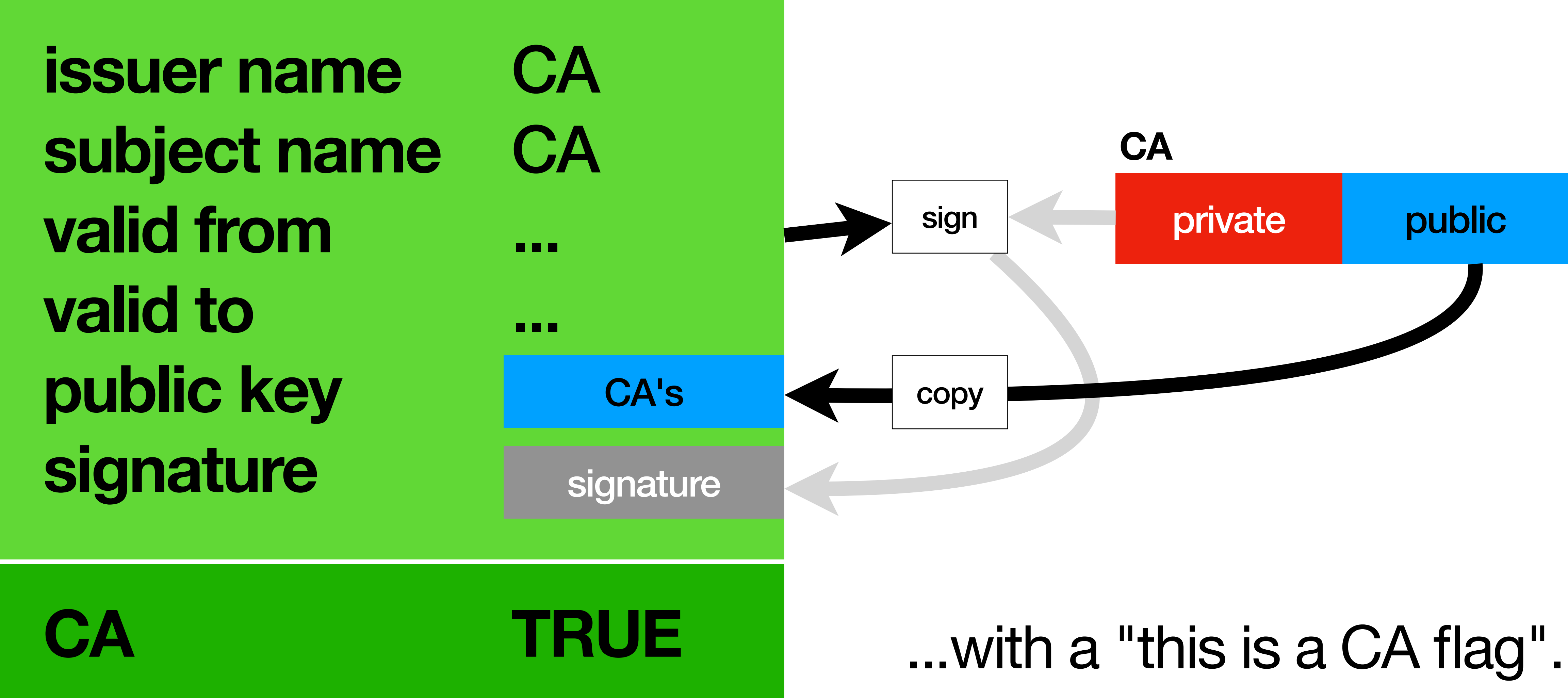
public

Certificate Authorities



Certificate Authorities are built on Self-Signed Certificates

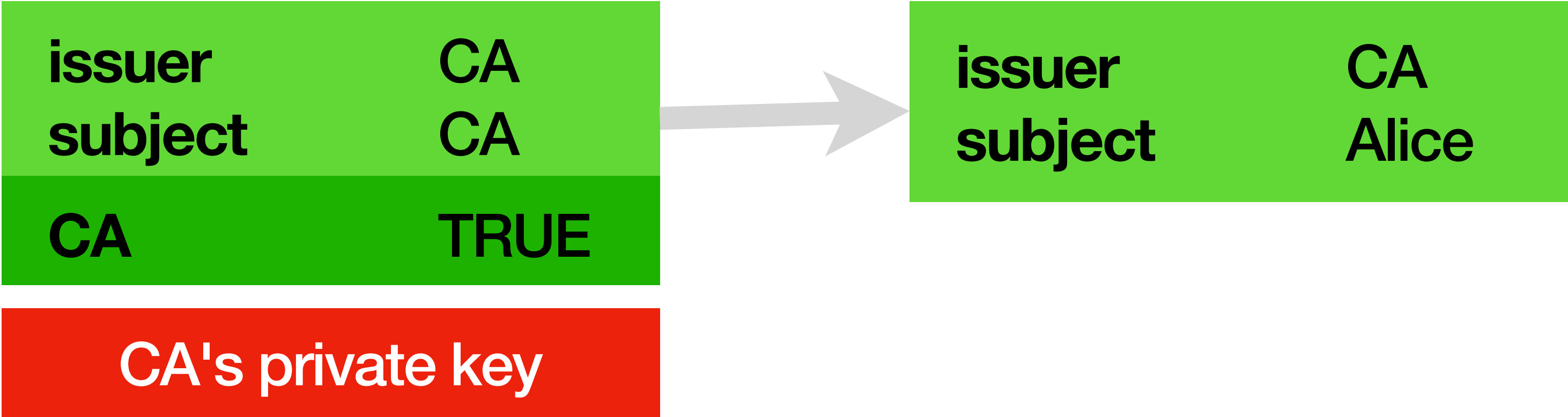
Certificate Authorities



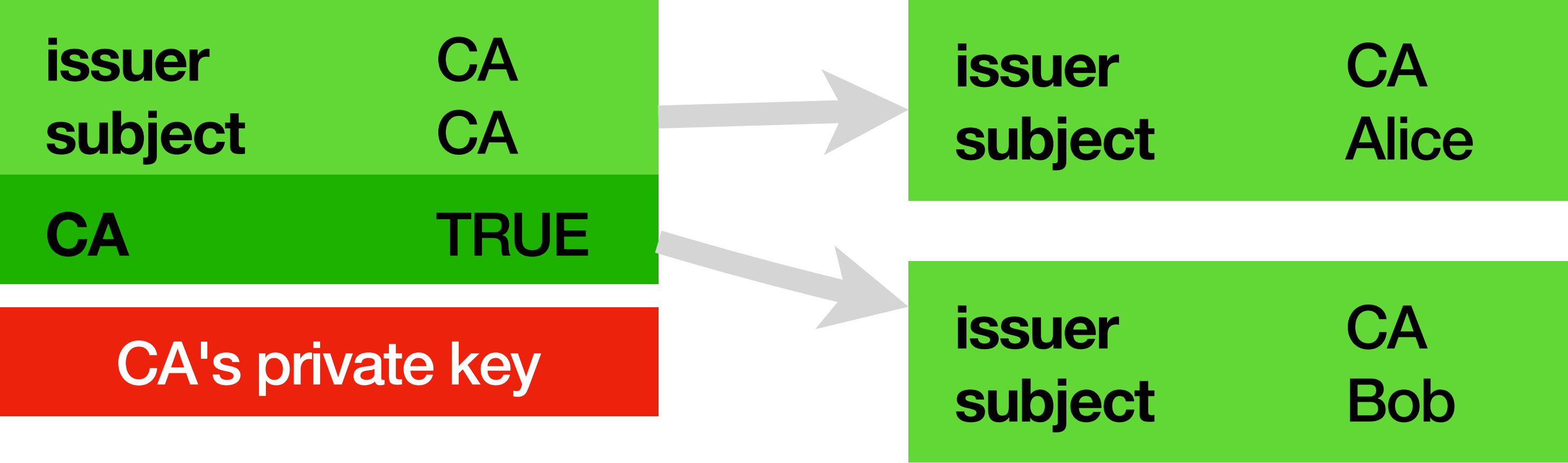
Certificate Authorities

issuer	CA
subject	CA
CA	TRUE
CA's private key	

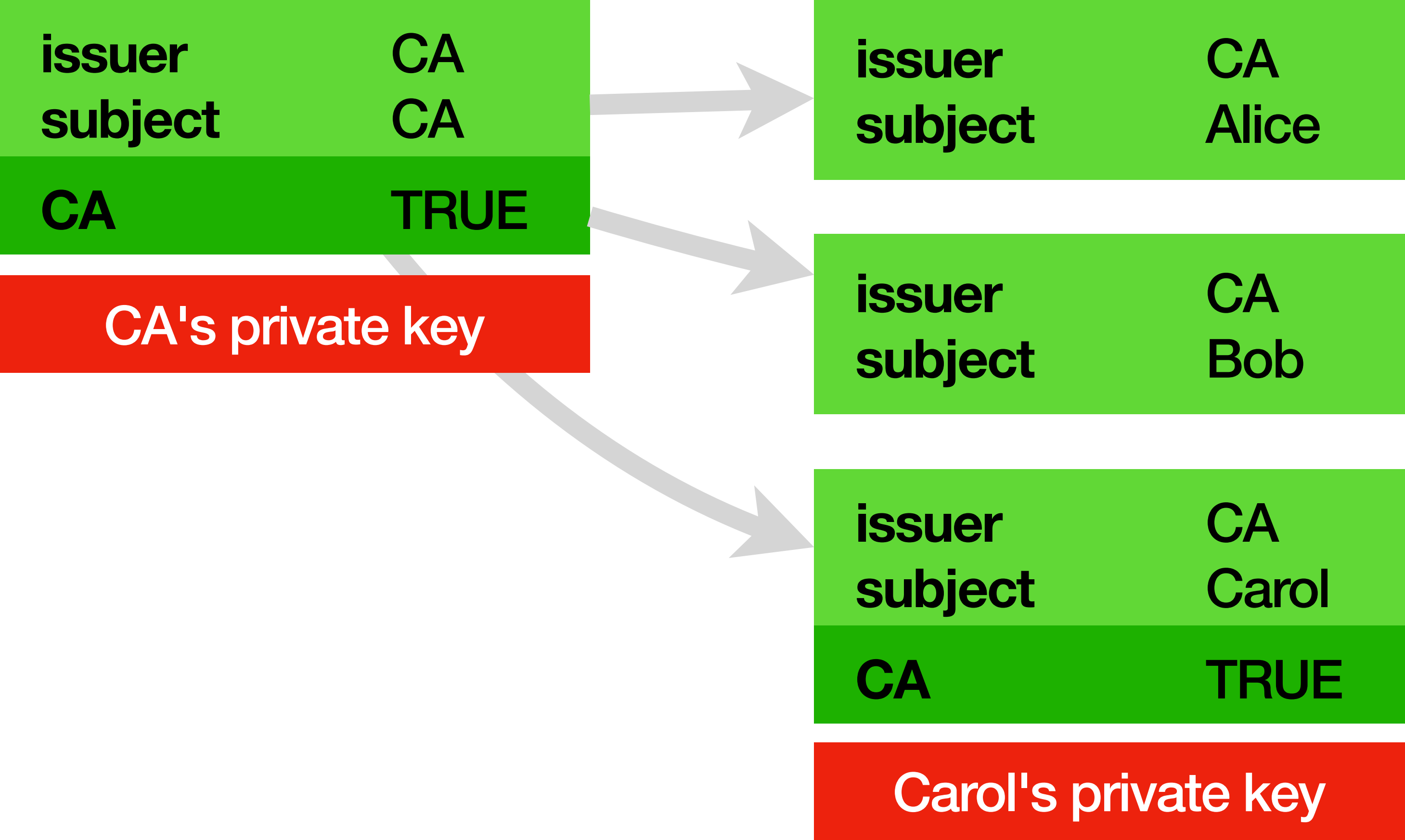
Certificate Authorities



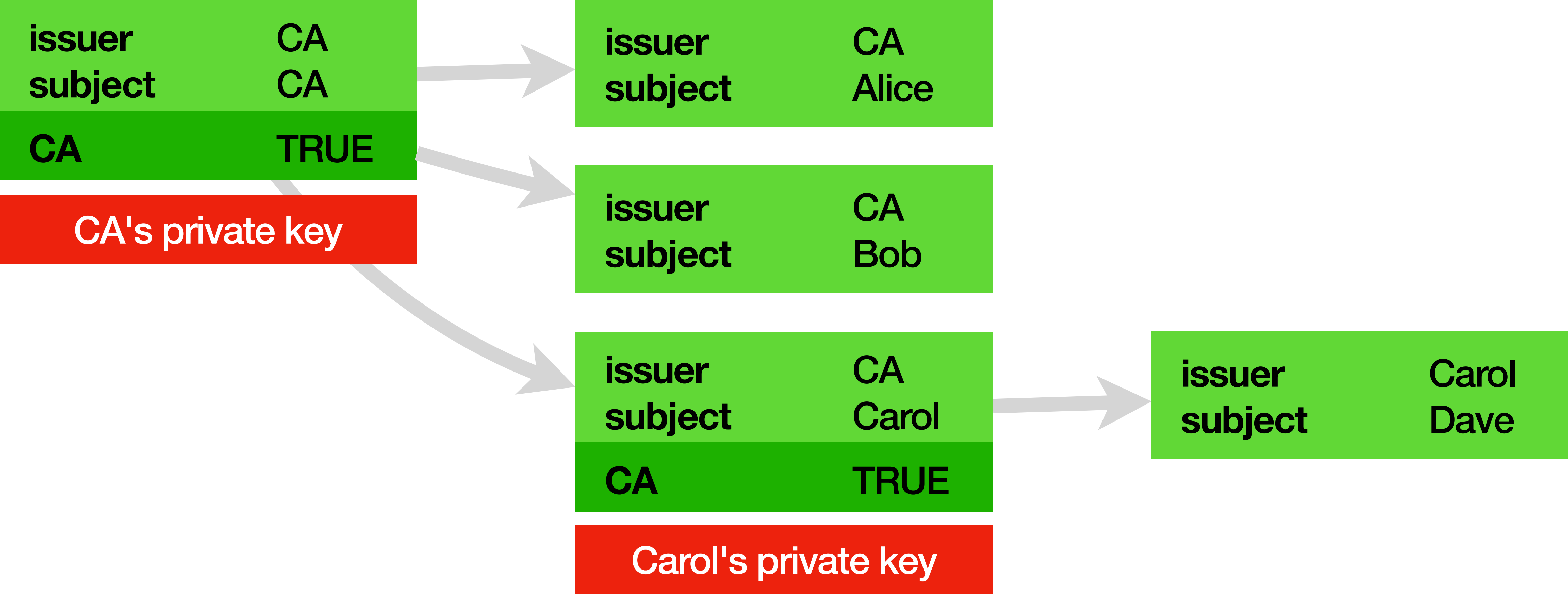
Certificate Authorities



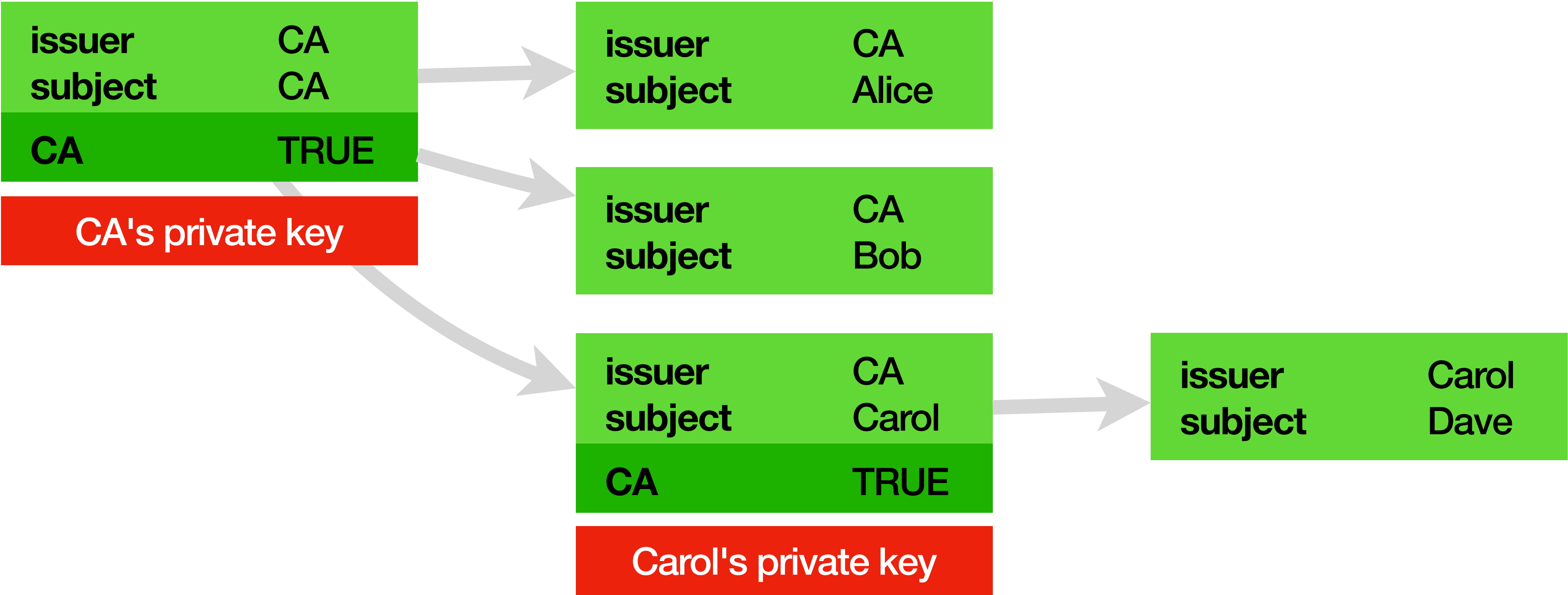
Certificate Authorities



Certificate Authorities



Certificate Authorities

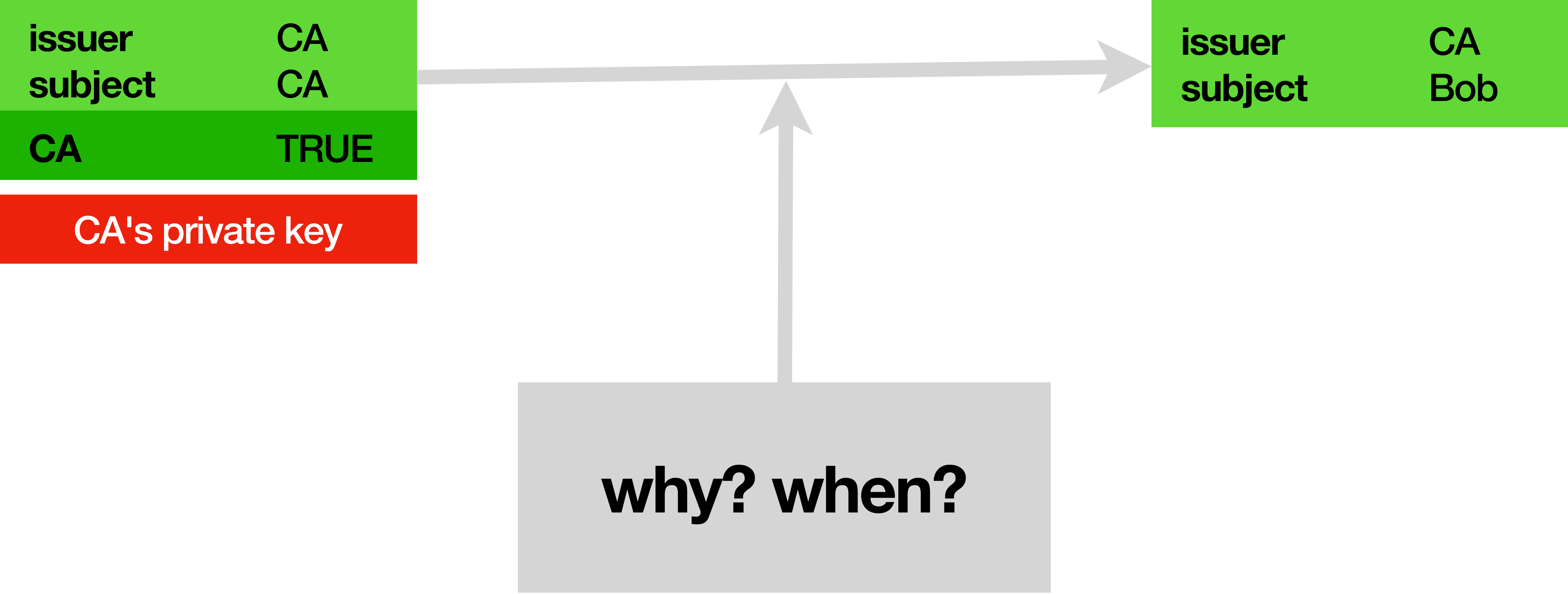


...turtles all the way down.

Certificate Authorities



Certificate Authorities



Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

Bob

private	public
---------	--------

Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

CA's world

public network

Bob

private	public
---------	--------

Bob's world

Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

CA's world

public network

Bob

private	public
---------	--------

Cert Signing Request

subject	Bob
---------	-----

Bob's world

Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

CA's world

public network

Bob

private	public
---------	--------

sign

Cert Signing Request

subject	Bob
signature	Bob's

Bob's world

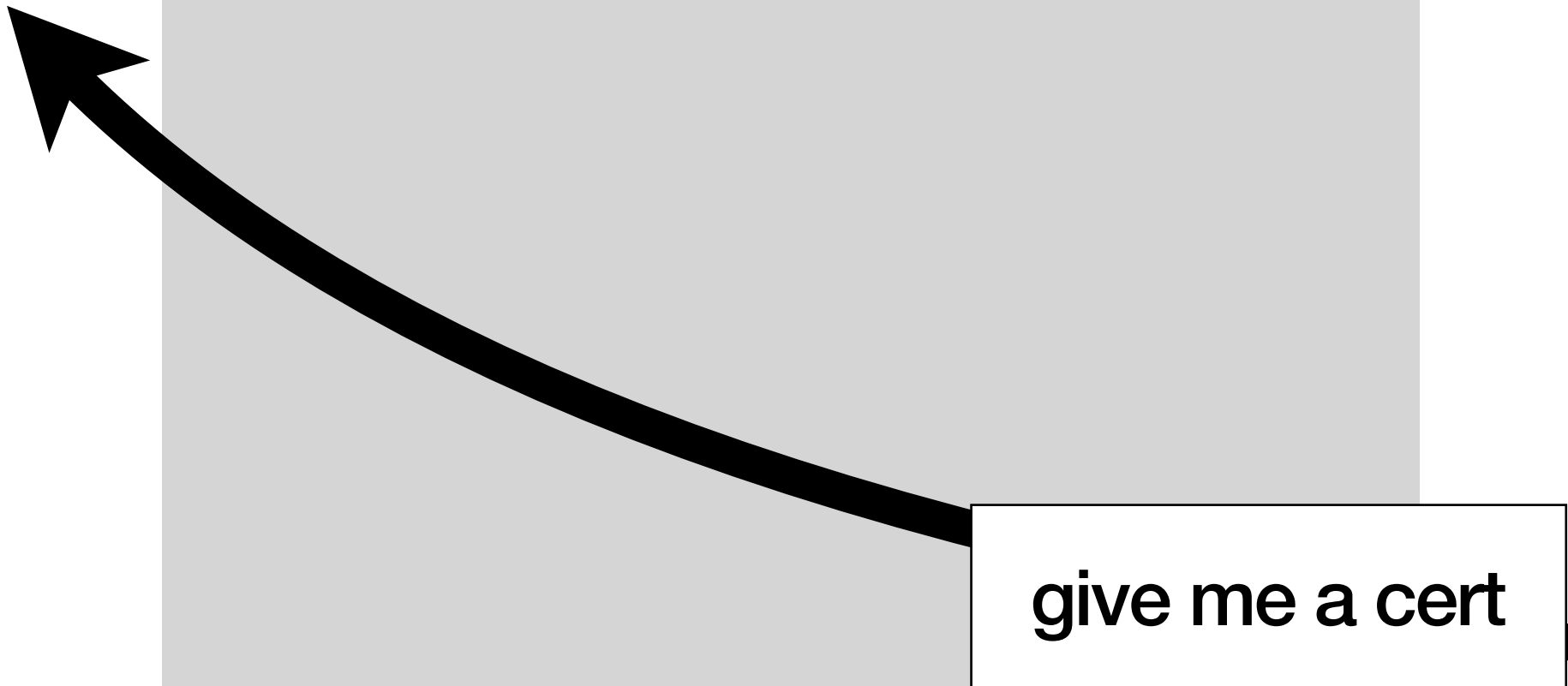
Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

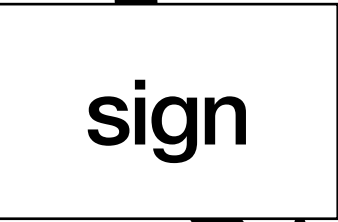
CA's world



public network

Bob

private	public
---------	--------



Cert Signing Request

subject	Bob
signature	Bob's

Bob's world

Certificate Authorities

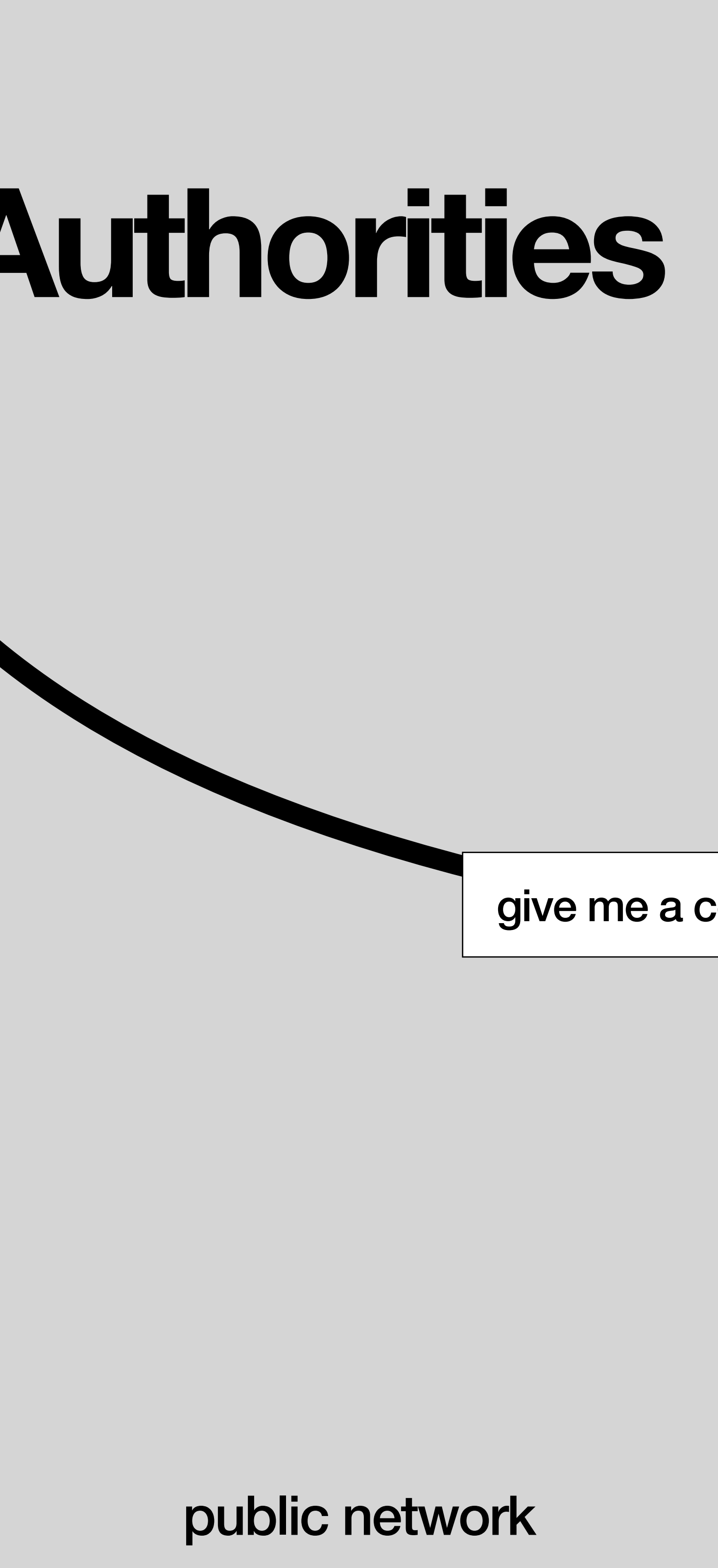
issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

issuer	CA
subject	Bob
public key	
signature	

CA's world



public network

Bob

private	public
---------	--------

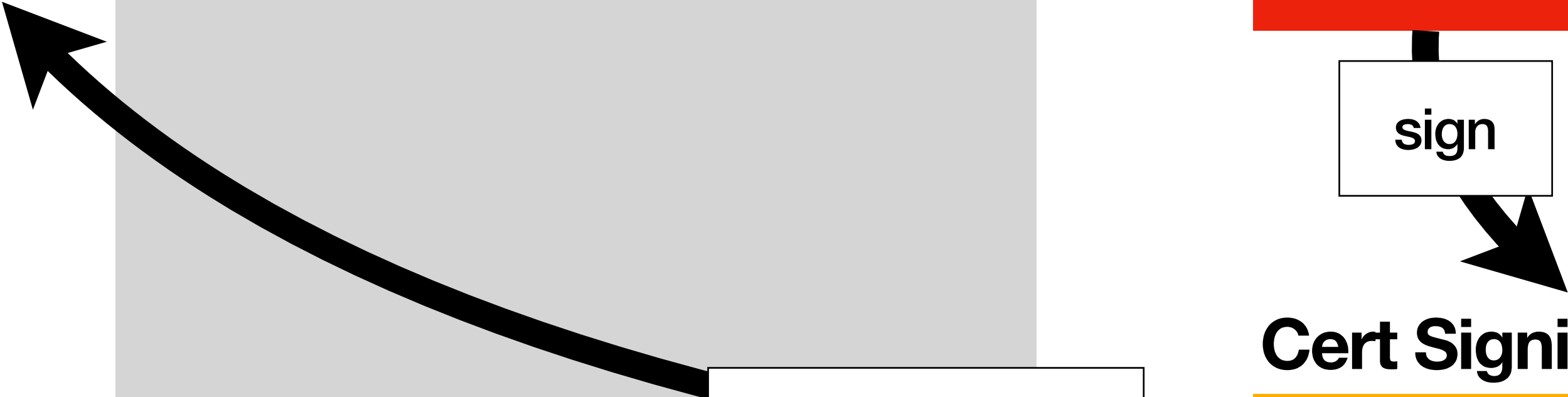


Cert Signing Request

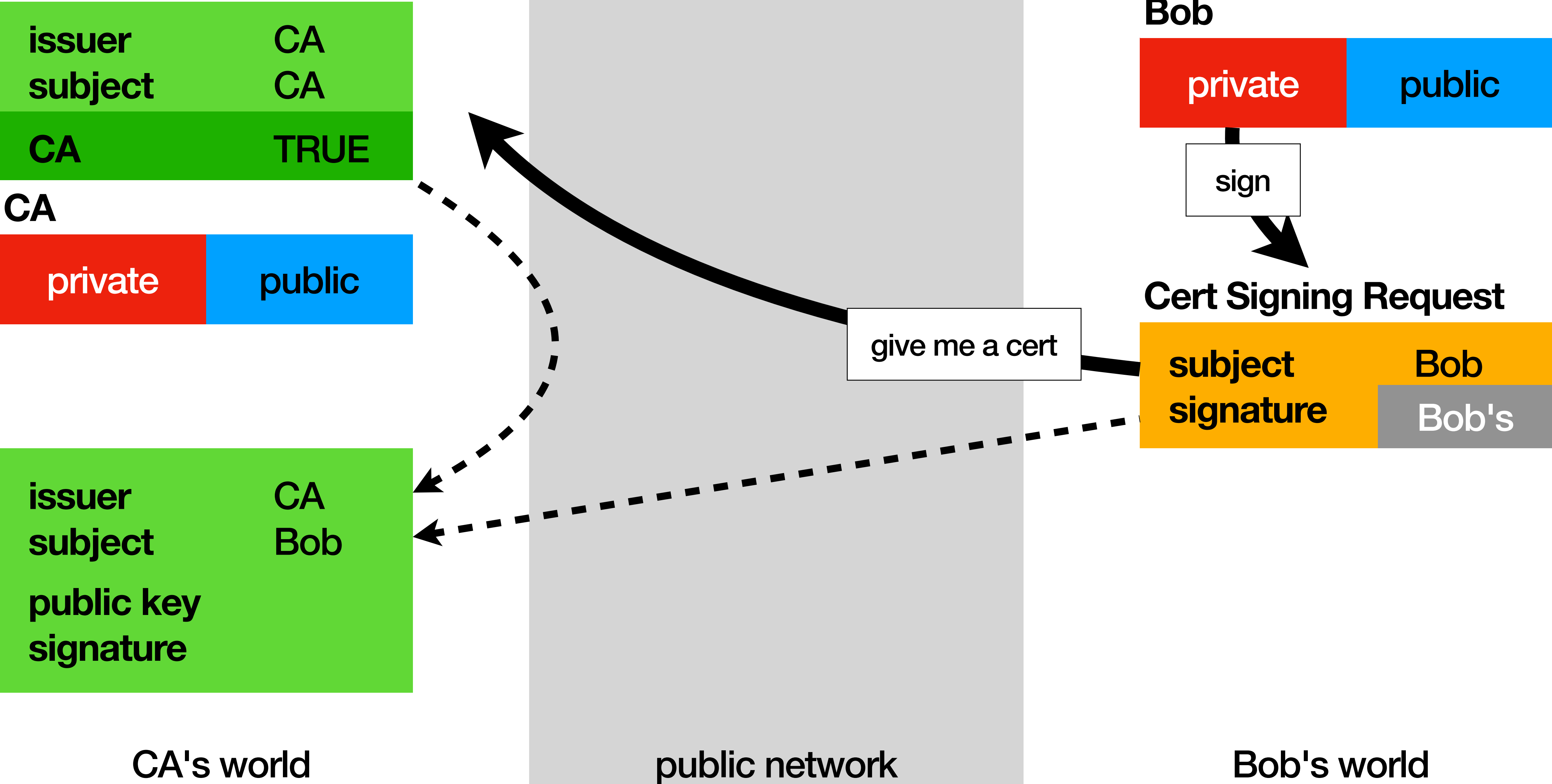
subject	Bob
signature	Bob's

Bob's world

give me a cert



Certificate Authorities



Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public
---------	--------

issuer	CA
subject	Bob
public key	Bob's
signature	

CA's world

public network

Bob

private	public
---------	--------

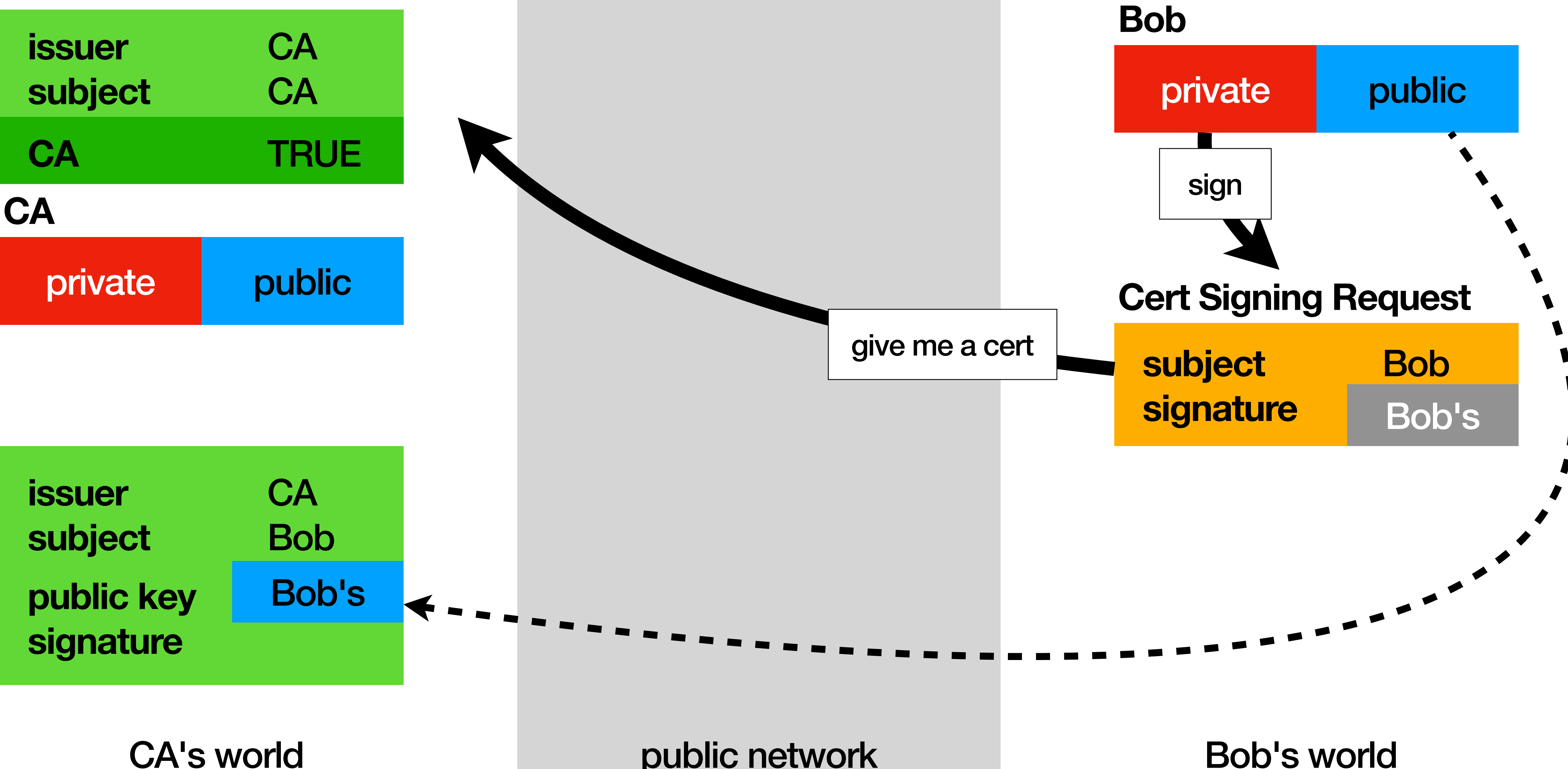
sign

Cert Signing Request

subject	Bob
signature	Bob's

Bob's world

give me a cert



Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

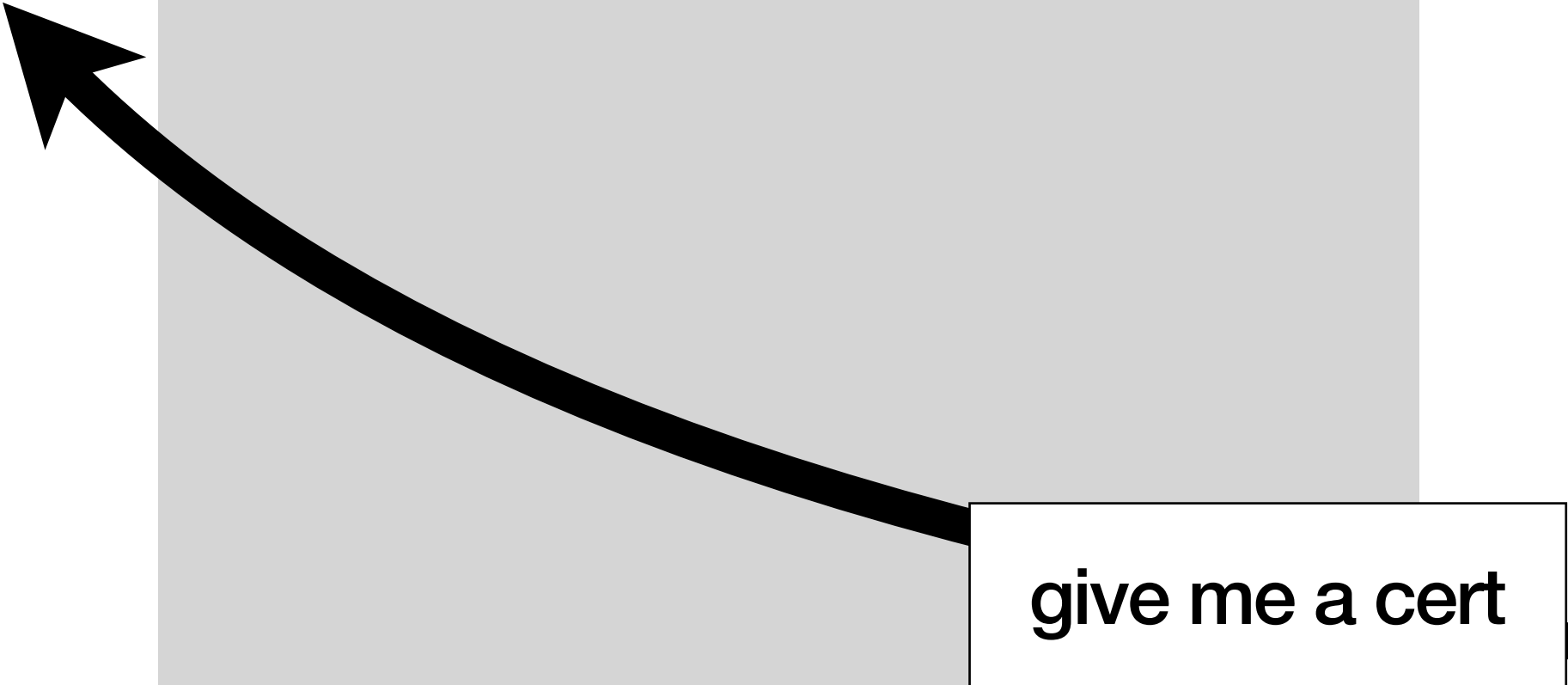
CA

private	public
---------	--------

sign

issuer	CA
subject	Bob
public key	Bob's
signature	CA's

CA's world



Bob

private	public
---------	--------

sign

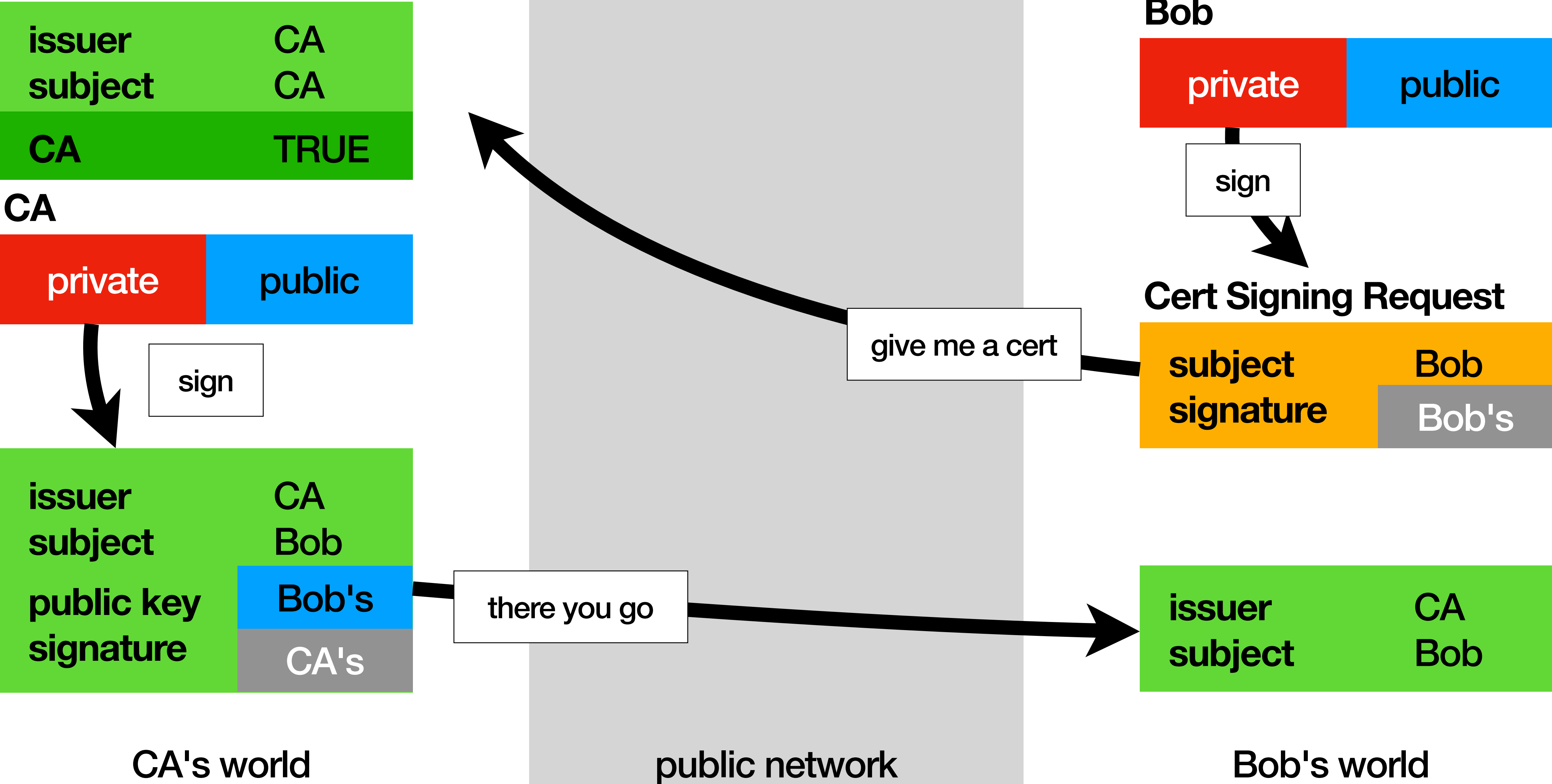
Cert Signing Request

subject	Bob
signature	Bob's

Bob's world

public network

Certificate Authorities

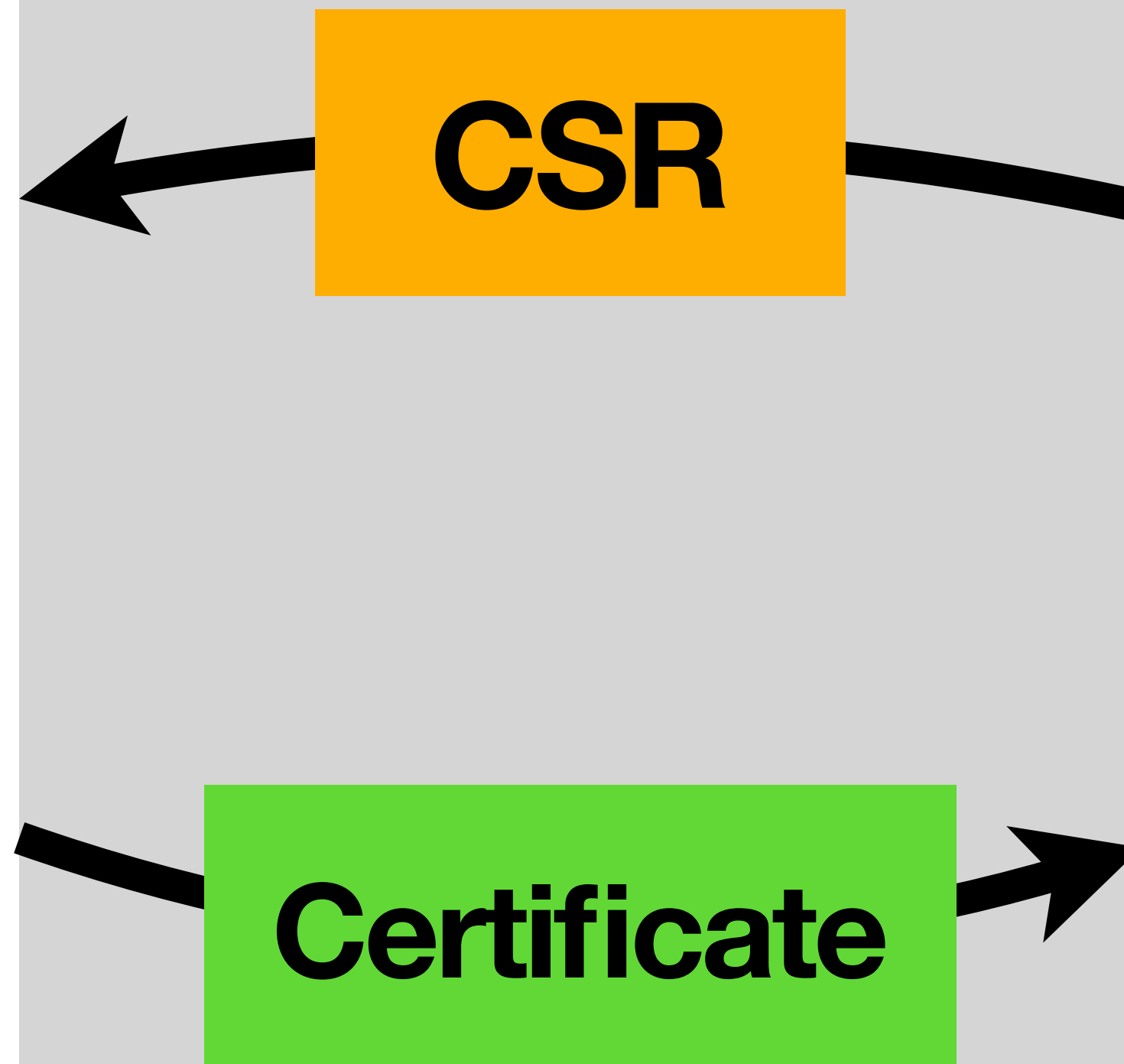


Certificate Authorities

CA's world

public network

Bob's world



...and TLS

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate servers using certificates**
- Clients connect, server sends certificate, client validates
- Authenticates server and supports private/encrypted traffic

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate servers using certificates**
- Clients connect, server sends certificate, client validates
- Authenticates server and supports private/encrypted traffic

*in **m(utual)TLS** clients also use certificates, server validated*

TLS Server Certificates

TLS Server Certificates

Bob serves a web app at
<https://example.com>.

TLS Server Certificates

Bob serves a web app at
`https://example.com`.

Needs a **server certificate**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

Bob serves a web app at **<https://example.com>**.

Needs a **server certificate**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

Bob serves a web app at **`https://example.com`**.

Needs a **server certificate**.

This is **not enough**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Bob serves a web app at **`https://example.com`**.

Needs a **server certificate**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Bob serves a web app at **`https://example.com`**.

Needs a **server certificate**.

Server certificates include **Subject Alternative Name**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Bob serves a web app at **`https://example.com`**.

Needs a **server certificate**.

Server certificates include **Subject Alternative Name**.

Also used in client validation.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Client Validation

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Client Validation

- Signature is valid.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Client Validation

- Signature is valid.
- Valid from/to is ok.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
------------	--------------------

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.
- Issued by a CA I trust.
or by a sub-CA of a CA I trust

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

SAN	example.com
-----	-------------

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.
- Issued by a CA I trust.
or by a sub-CA of a CA I trust

...there is much more!

CAs & TLS

CAs & TLS

who you trust dictates everything

MITM (aka Man-in-the-middle)

MITM (aka Man-in-the-middle)

web application at
<http://example.com>

Alice's client

public network

Bob's server

MITM (aka Man-in-the-middle)

HTTP client (no TLS)

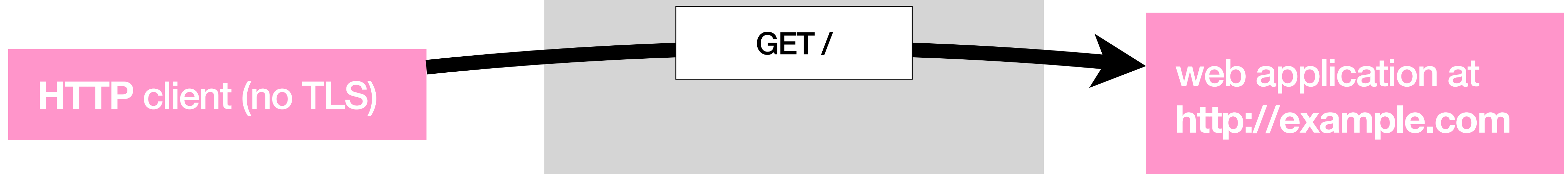
web application at
<http://example.com>

Alice's client

public network

Bob's server

MITM (aka Man-in-the-middle)

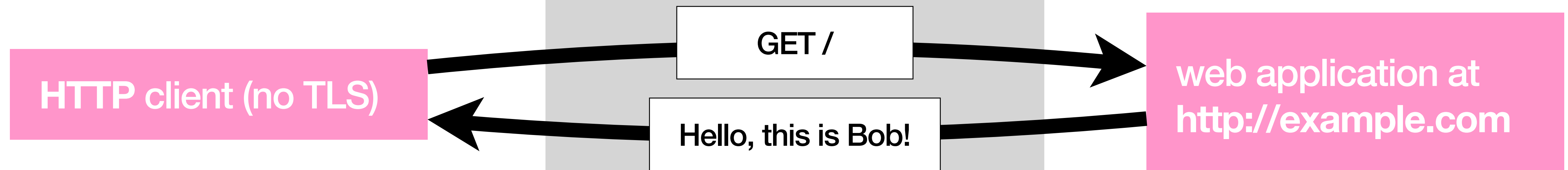


Alice's client

public network

Bob's server

MITM (aka Man-in-the-middle)



Alice's client

public network

Bob's server

MITM (aka Man-in-the-middle)

HTTP client (no TLS)

web application at
<http://example.com>

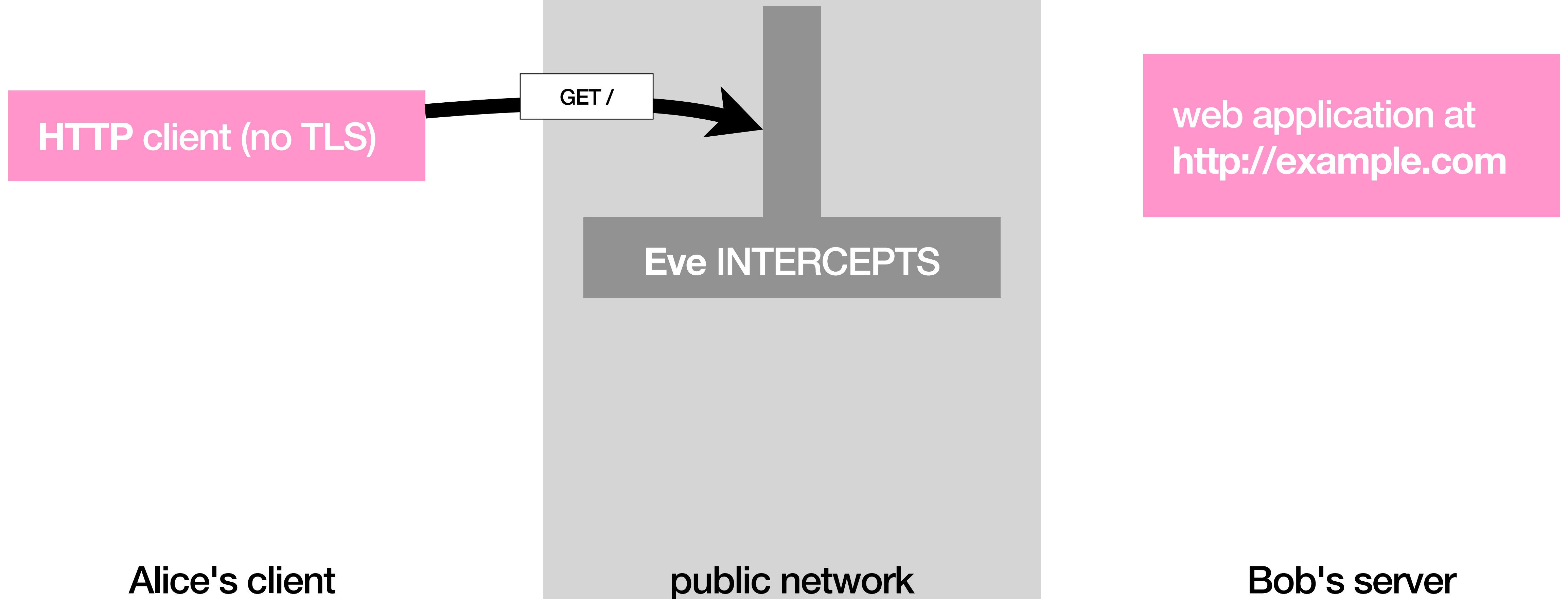
Eve INTERCEPTS

Alice's client

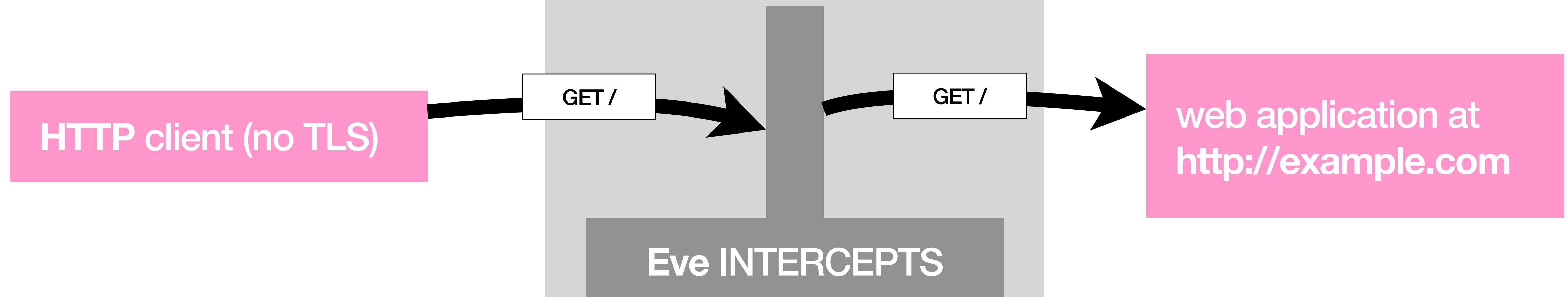
public network

Bob's server

MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)

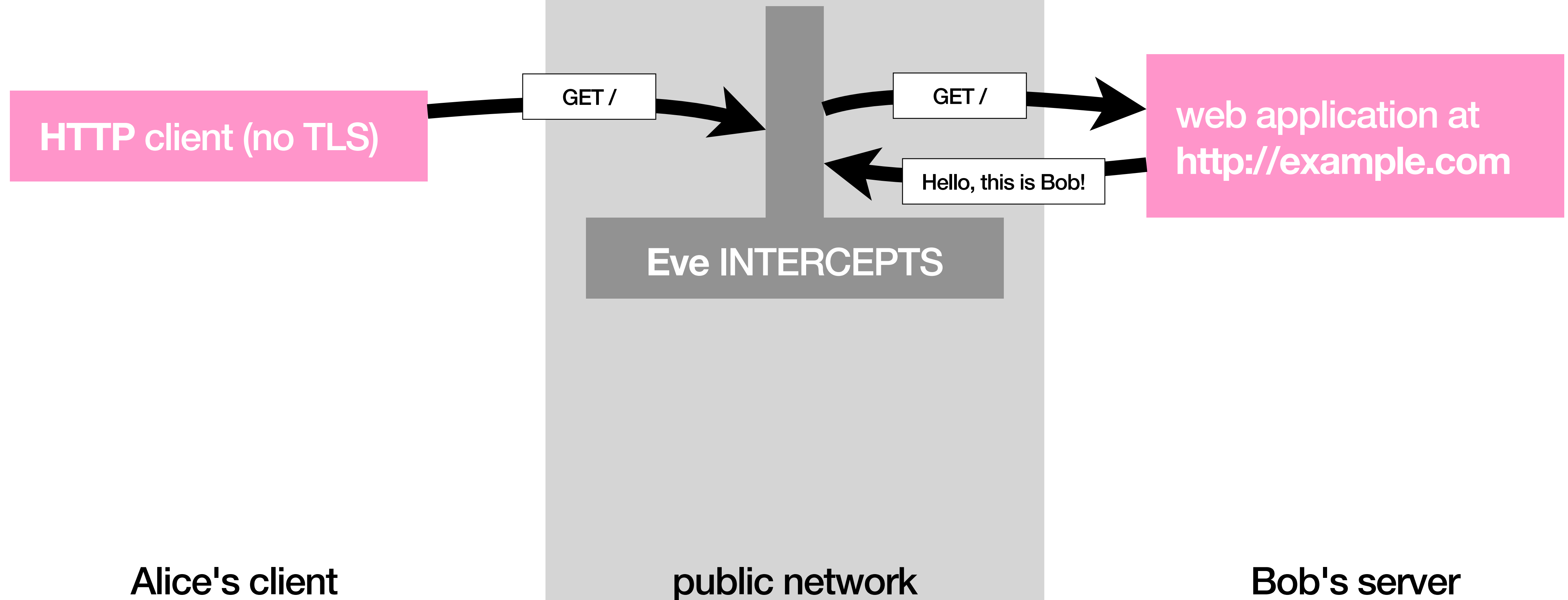


Alice's client

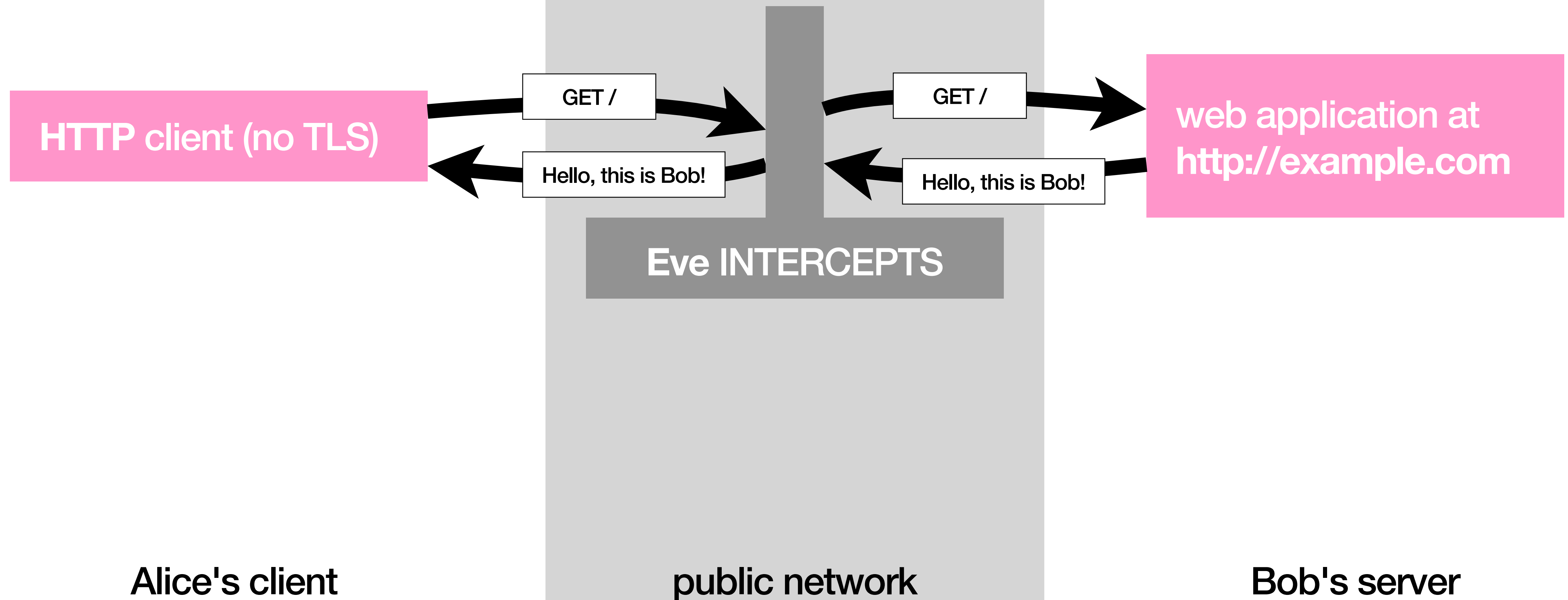
public network

Bob's server

MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



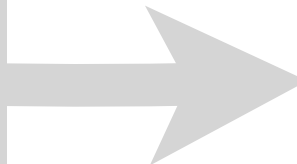
MITM (aka Man-in-the-middle)

HTTPS client

Alice's client

issuer	CA
subject	CA
CA	TRUE

public network

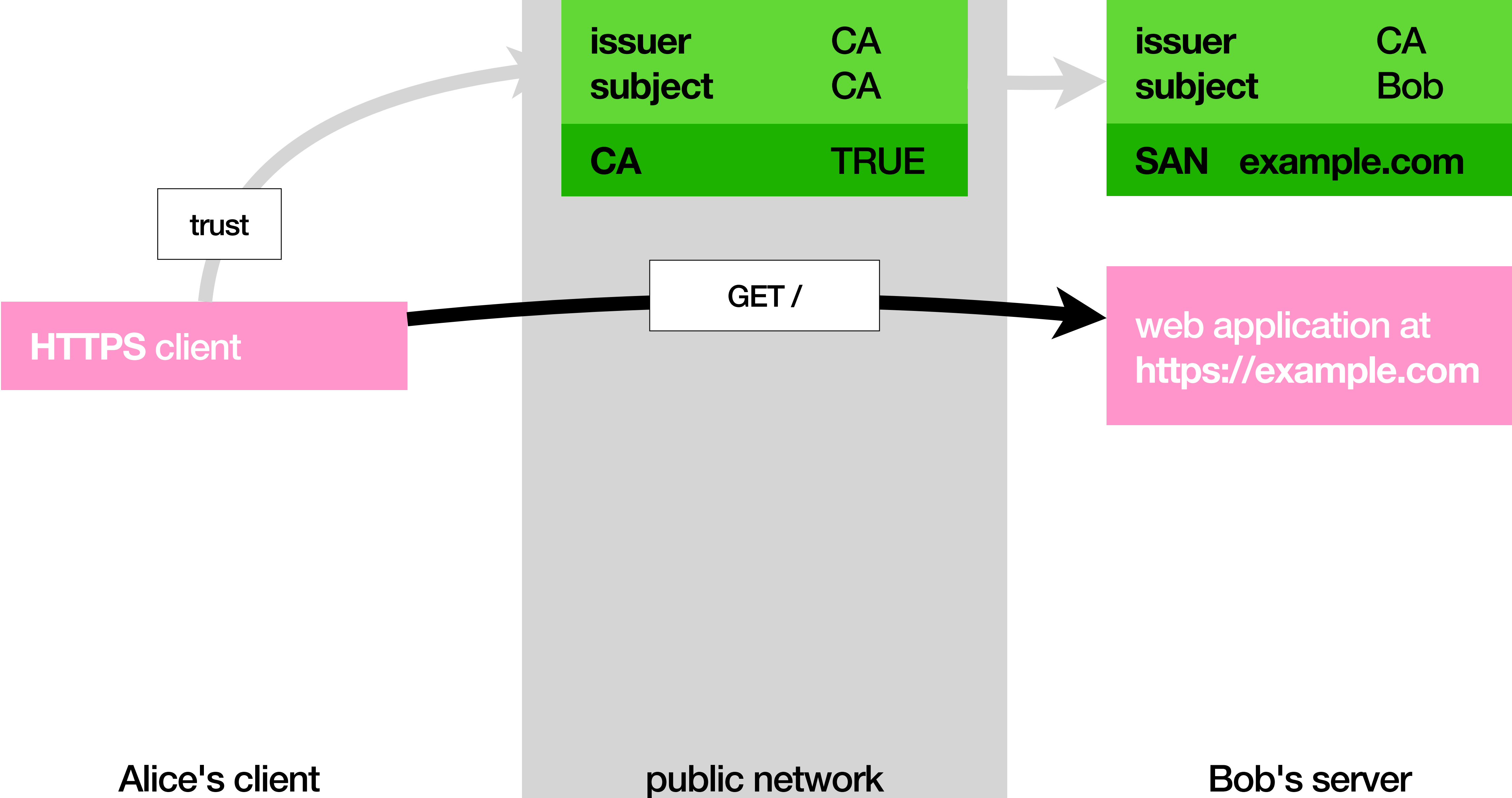


issuer	CA
subject	Bob
SAN	example.com

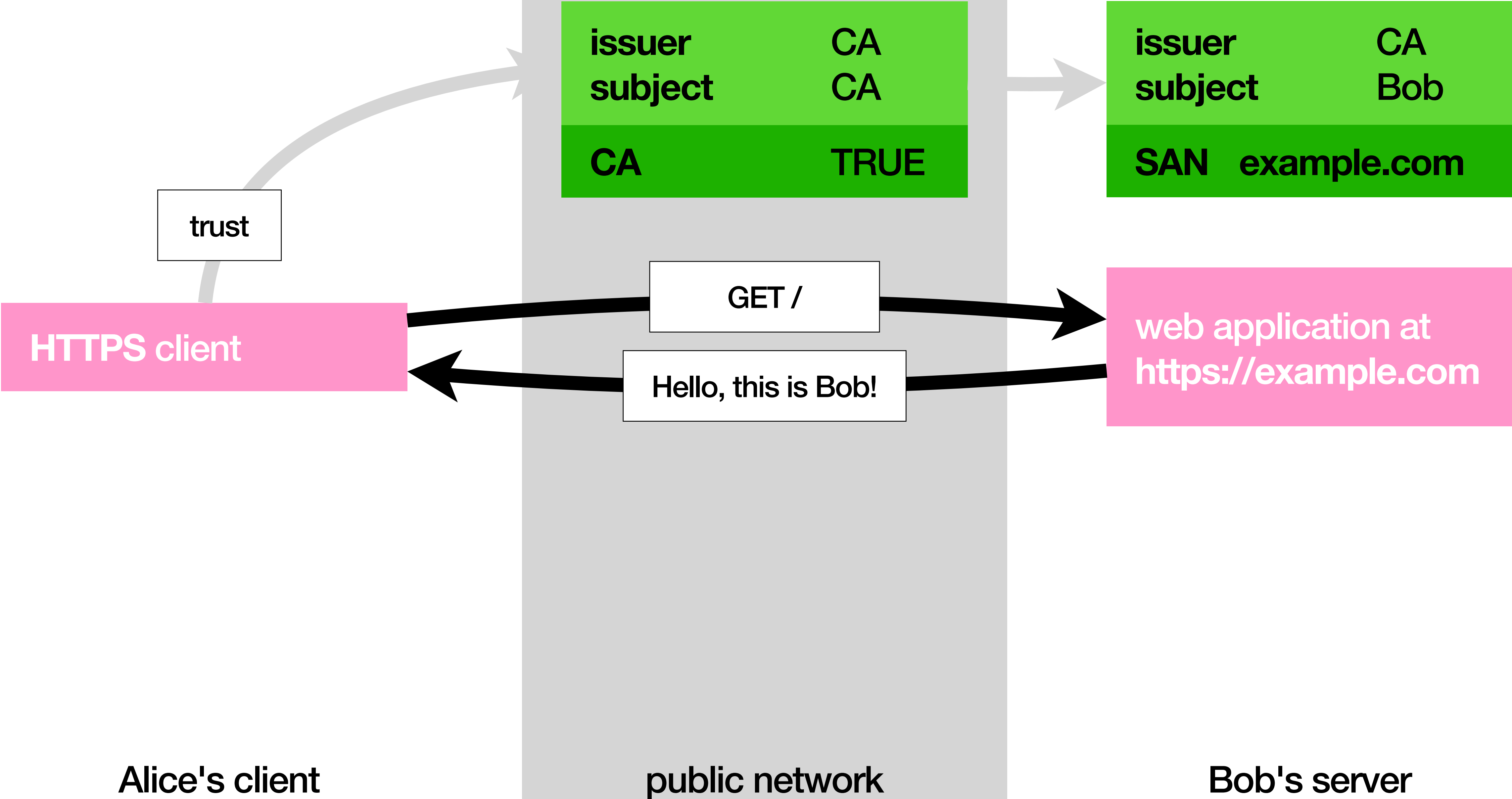
web application at
<https://example.com>

Bob's server

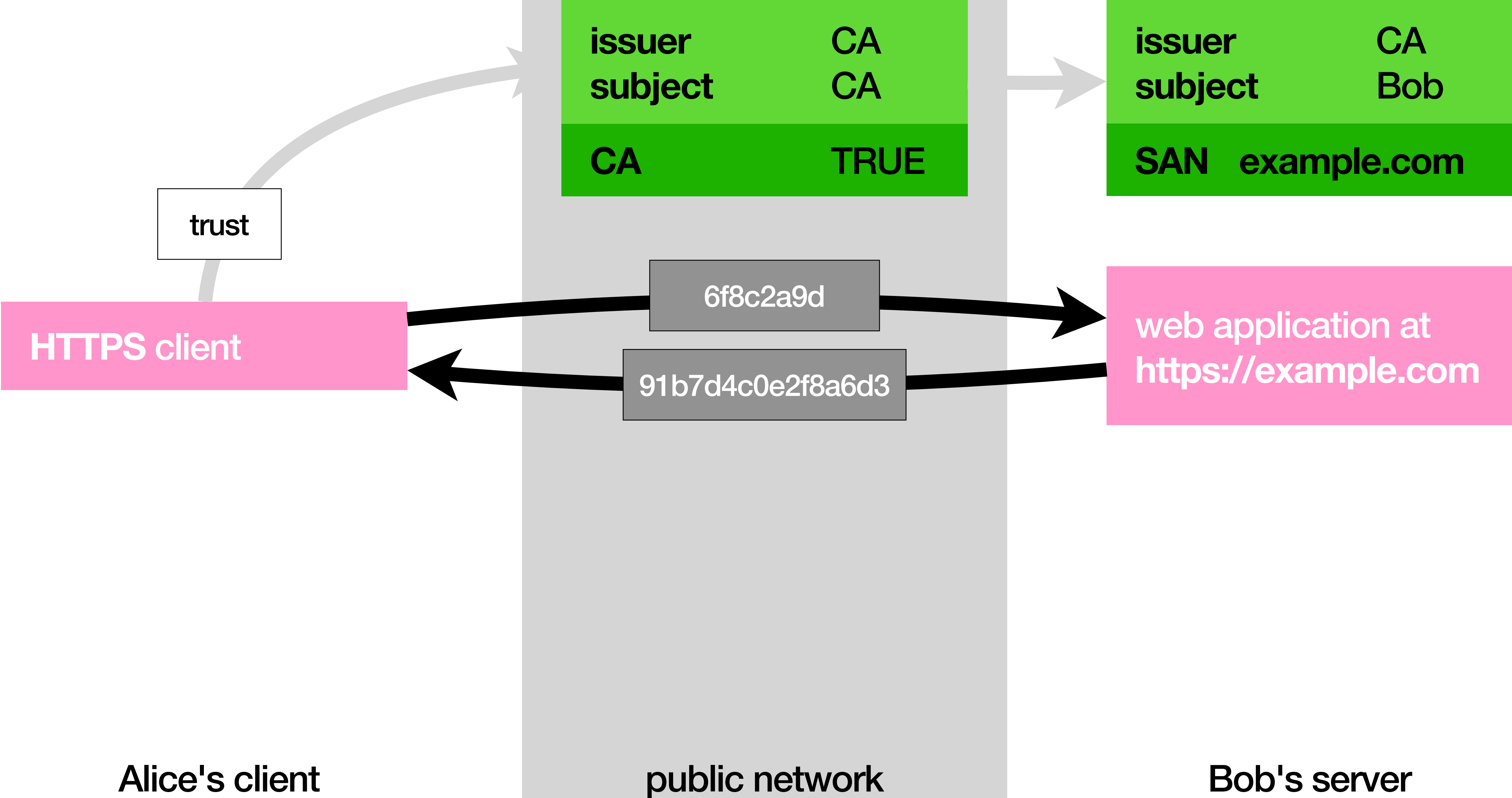
MITM (aka Man-in-the-middle)



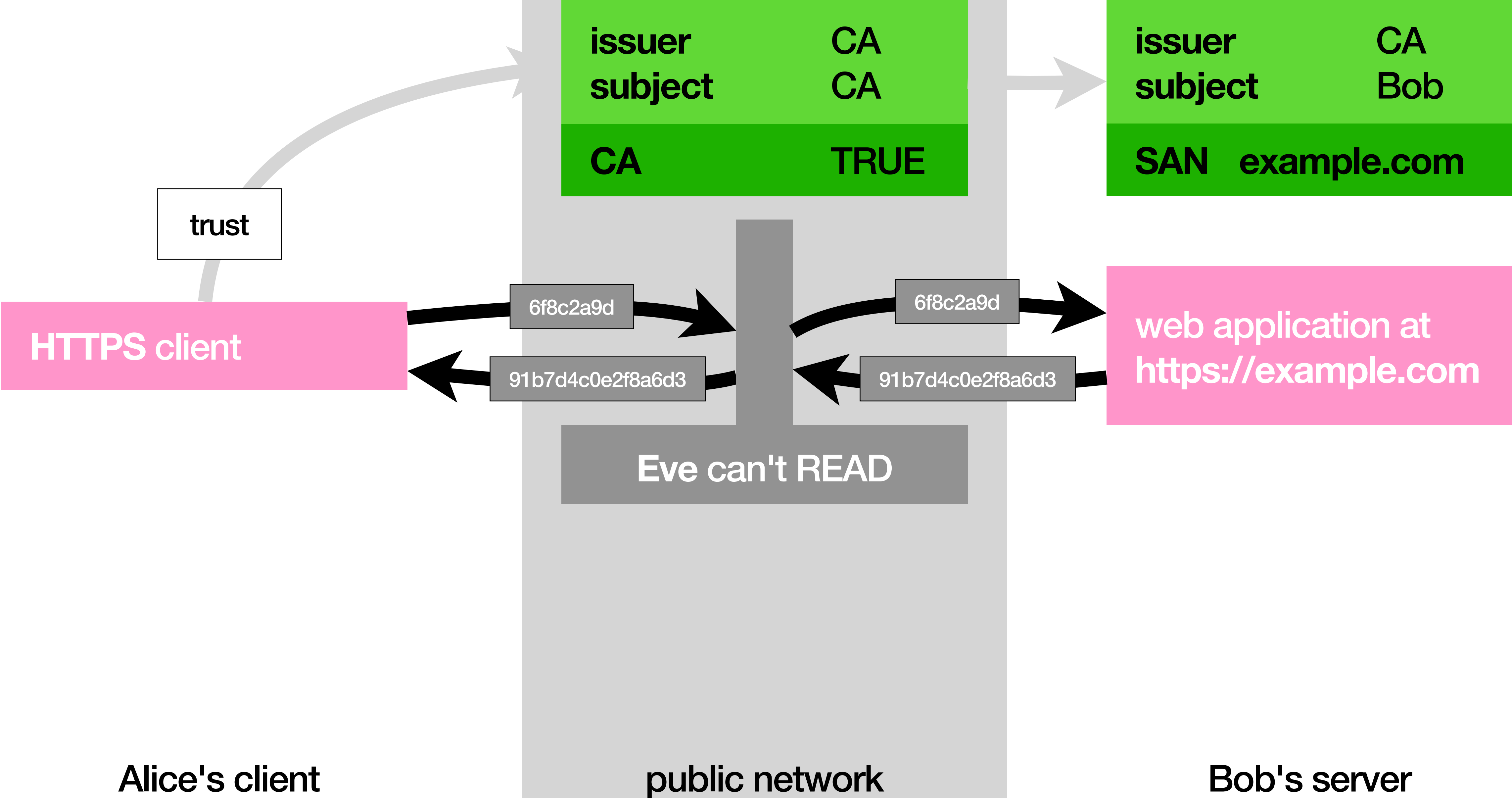
MITM (aka Man-in-the-middle)



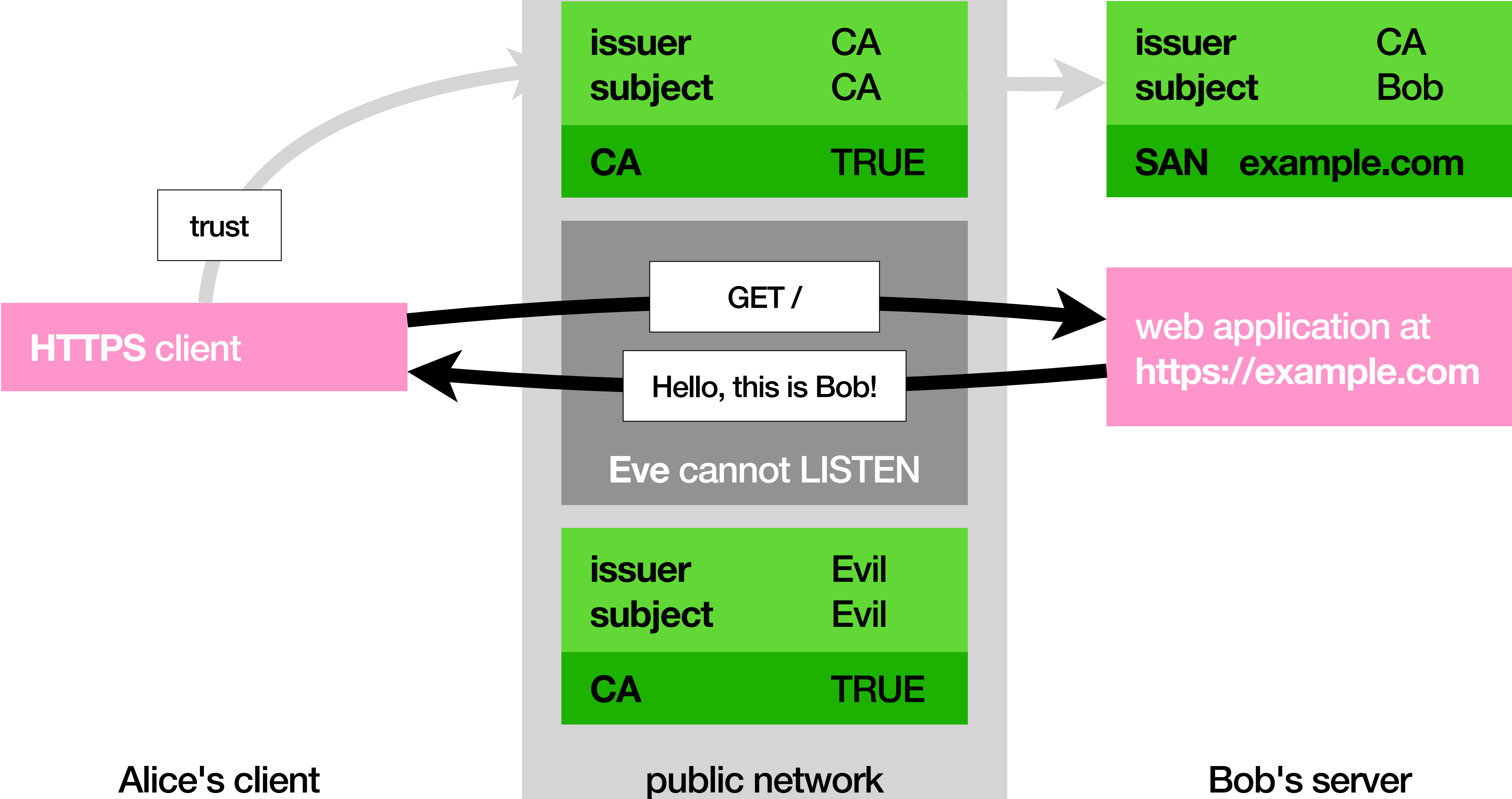
MITM (aka Man-in-the-middle)



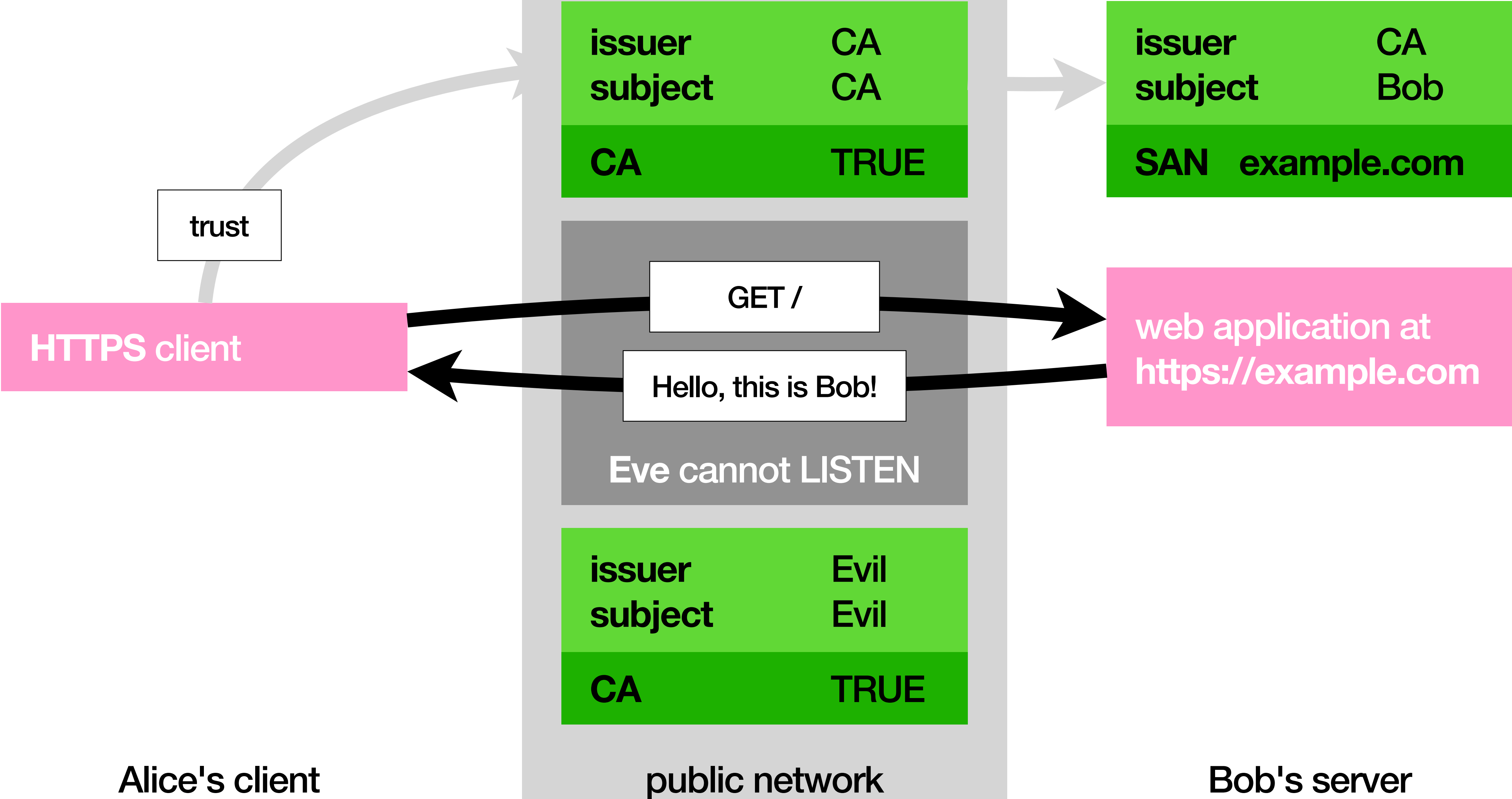
MITM (aka Man-in-the-middle)



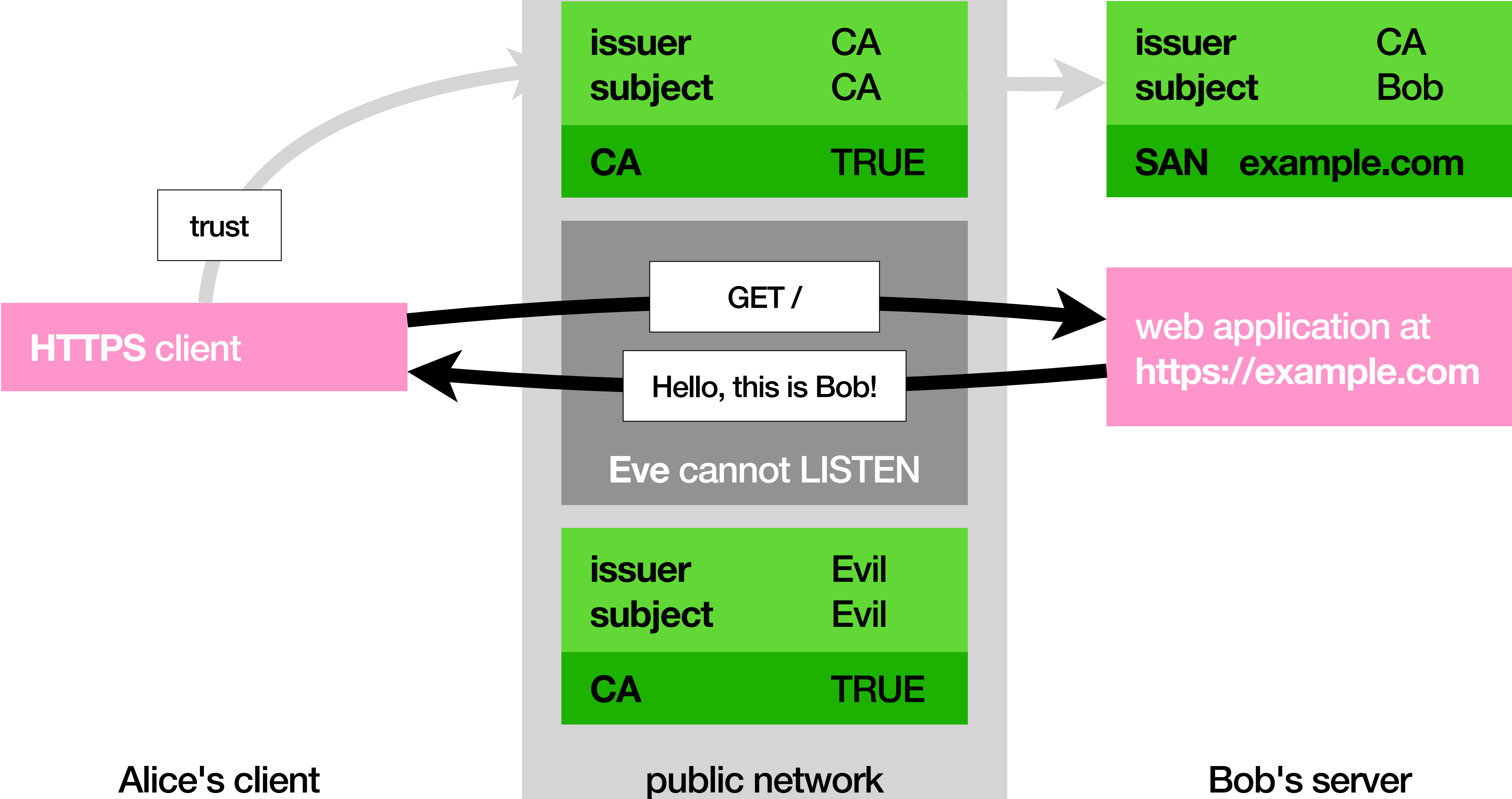
MITM (aka Man-in-the-middle)



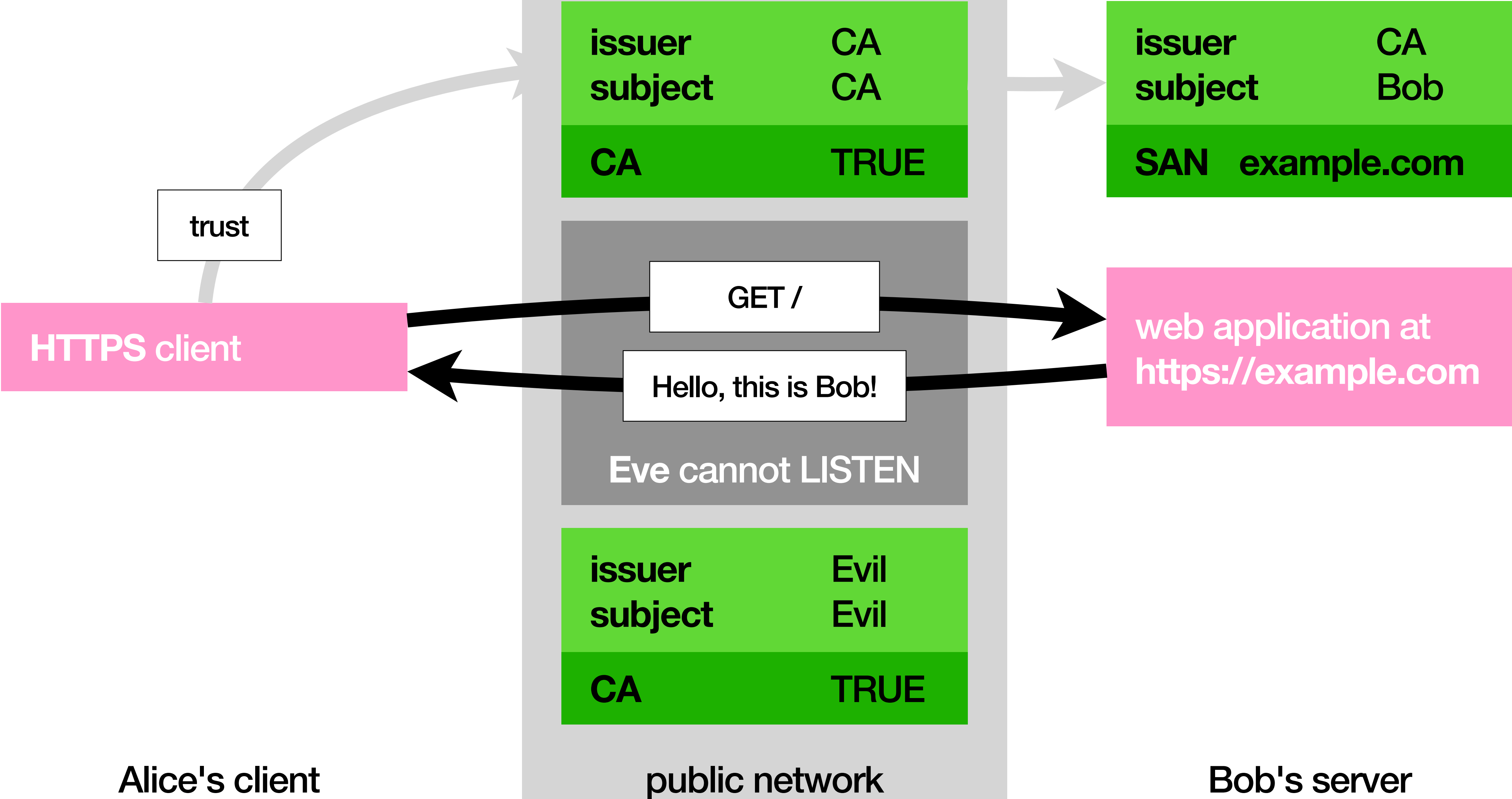
MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)

